



Bundesamt
für Sicherheit in der
Informationstechnik

Deutschland
Digital•Sicher•BSI

Leitfaden zur Methodik Grundschutz++



Änderungshistorie

<i>Version</i>	<i>Datum</i>	<i>Name</i>	<i>Beschreibung</i>
März 2026	16.03.2026	BSI und SdT- Community	Erstellung eines Leitfadens zur Methodik Grundschutz++

Tabelle 1: Änderungshistorie

Inhalt

1	Einleitung und Zielsetzung.....	7
1.1	Hintergrund und Motivation.....	7
1.2	Zielgruppen und Anwendungsbereiche.....	7
1.3	Konzeptstruktur.....	8
1.4	Überblick über den Sicherheitsprozess nach GS++.....	8
1.4.1	Überblick Prozessschritt 1 – Erhebung und Planung.....	9
1.4.2	Überblick Prozessschritt 2 – Anforderungsanalyse.....	9
1.4.3	Überblick Prozessschritt 3 – Realisierung.....	10
1.4.4	Überblick Prozessschritt 4 – Überwachung.....	10
1.4.5	Überblick Prozessschritt 5 – kontinuierliche Verbesserung.....	10
1.4.6	Überblick PDCA-Zyklus.....	11
2	Prozessschritt 1 – Erhebung und Planung.....	12
2.1	Festlegung des Kontextes der Institution.....	12
2.2	Implementierung des Compliance-Managements.....	12
2.3	Analyse der interessierten Parteien.....	13
2.4	Entwicklung der Informationssicherheitsleitlinie.....	14
2.5	Festlegung des Geltungsbereichs.....	14
2.6	Prozess der Informationssicherheitseinstufung.....	15
2.7	Sicherheitsorganisation und Rollen.....	15
2.8	Dokumentation und Kommunikation.....	16
2.9	Festlegung und Freigabe der Vorgehensweise.....	17
2.10	Initiierung des Risikomanagements.....	17
3	Prozessschritt 2 – Anforderungsanalyse.....	19
3.1	Definition und Abgrenzung des Informationsverbunds.....	19
3.2	Übersicht über die Erstellung eines Anforderungspakets.....	20
3.3	ISMS-Anforderungen des Informationsverbundes.....	21
3.4	Asset-Modellierung.....	21
3.4.1	Erfassung relevanter Assets.....	22
3.4.2	Mapping der Assets auf die Zielobjektkategorien.....	22
3.5	Anforderungsmodellierung auf die Assets.....	24
3.5.1	Vererbung von Zielobjektkategorien.....	24
3.5.2	Modellierung der Anforderungen mit Bezug zu einer Zielobjektkategorie.....	24
3.5.3	Konsolidierung und Redundanzprüfung.....	25
3.5.4	Modellierung der Anforderungen ohne Zielobjektkategorie.....	25
3.6	Anforderungsergänzungen.....	25
3.6.1	Aufgrund anforderungsloser Assets.....	25

3.6.2	Aufgrund externer Verpflichtungen.....	26
3.7	Überprüfung des gesetzten Sicherheitsniveaus.....	26
3.8	Durchführung der Risikobetrachtung.....	27
3.9	Gestaltungsentscheidungen	27
3.9.1	Verteilung der führenden Zuständigkeiten	27
3.9.2	Weitere Parameter	27
4	Prozessschritt 3 – Realisierung.....	28
4.1	Ermittlung des Umsetzungsstatus	28
4.2	Bewertung fehlender Umsetzungen	29
4.3	Umsetzungsplanung und Priorisierung	29
4.4	Zuständigkeiten und Umsetzungsfristen.....	29
4.5	Freigabeverfahren und Ausnahmemanagement.....	30
4.6	Fortschrittsverfolgung der Realisierung.....	30
4.7	Wahrung von Compliance in der Umsetzung	31
5	Prozessschritt 4 – Überwachung	32
5.1	Leistungsbewertung des ISMS	32
5.2	Überwachung der Compliance.....	33
5.3	Auditprogramm und -durchführung	33
5.4	Bewertungsschema und Auditberichte.....	34
5.5	Managementbewertung	35
5.6	Monitoringmethoden und -tools.....	35
5.7	Validierung der Anforderungen.....	36
6	Prozessschritt 5 – kontinuierliche Verbesserung	37
6.1	Umgang mit Nicht-Konformitäten	37
6.2	Identifikation von Verbesserungspotenzialen.....	38
6.3	Korrektur- und Verbesserungsvorschläge.....	39
6.4	Korrektur- und Verbesserungsplanung.....	39
6.5	Wirksamkeitsprüfung	40
6.6	Bewertung der erreichten Verbesserung.....	40
6.7	Behandlung von Compliance-Verstößen	41
7	Grundlegende Begriffe.....	43
7.1	Anforderungen.....	43
7.2	Assets.....	43
7.3	Geltungsbereich des ISMS	43
7.4	Informationssicherheitsmanagementsystem (ISMS).....	43
7.5	Informationsverbund.....	43
7.6	Maßnahmen	44
7.7	Praktiken.....	44

7.8	Risikobetrachtung.....	44
7.9	Schutzbedarf.....	44
7.10	Informationssicherheitseinstufung.....	44
7.11	Informationssicherheitsleitlinie	44
7.12	Sicherheitsniveau	44
7.13	Zielobjektkategorien.....	45

Abbildungsverzeichnis

Abbildung 1 Layer	8
Abbildung 2 Überblick über die Schritte des Sicherheitsprozesses der Methodik-GS++	9
Abbildung 3 Aufteilung der Prozessschritte im PDCA-Zyklus.....	11
Abbildung 4 Praktiken.....	19
Abbildung 5 Anforderungsmodellierung	21
Abbildung 6 Zielobjektkategorien und Vererbung.....	23
Abbildung 7 Prozessschritt 4: Überwachung	32

1 Einleitung und Zielsetzung

1.1 Hintergrund und Motivation

Die Entwicklung des Grundschutz++ (GS++) ist ein konsequenter Schritt in der Evolution des IT-Grundschutzes des BSI als Reaktion auf die sich wandelnde Informationssicherheitslandschaft. Basierend auf umfangreichen praktischen Erfahrungen und dem Feedback zahlreicher Anwenderinnen und Anwender wurden in der bisherigen IT-Grundschutz-Methodik verschiedene Herausforderungen identifiziert, die in die Methodik GS++ eingeflossen sind.

Die Methodik befindet sich derzeit in der Einführungs- und Erprobungsphase. Sie ermöglicht es den Anforderungskatalog-GS++ der Stand der Technik Bibliothek [github: Stand-der-Technik-Bibliothek](#) in strukturierter Form zu nutzen.

1.2 Zielgruppen und Anwendungsbereiche

Dieser Leitfaden beschreibt die Methodik-GS++ und gibt somit eine Anleitung dafür, ein Informationssicherheitsmanagementsystem (ISMS) für die eigene Institution aufzubauen und fortzuentwickeln.

Zielgruppe sind Institutionsleitende, Management, Entscheidende, Informationssicherheits-beauftragte (ISB), IKT-Betriebsleiter, usw.

Die Methodik-GS++ richtet sich an ein breites Spektrum von Institutionen und berücksichtigt deren unterschiedliche Ausgangslagen, Ressourcen und Bedürfnisse:

Kleine Institutionen profitieren von einem Einstieg in das systematische Informationssicherheitsmanagement. Die Methodik ermöglicht es, mit begrenzten personellen und zeitlichen Ressourcen ein Sicherheitsniveau gemäß Stand der Technik (SdT) zu etablieren. Langfristig empfehlen wir die toolgestützte Umsetzung.

Mittlere Institutionen können durch teilweise Automatisierung und skalierbare Prozesse effizienter arbeiten. Die Methodik unterstützt sowohl den manuellen als auch den teilautomatisierten Betrieb eines ISMS und bietet praxisorientierte Ansätze für den schrittweisen Ausbau des Sicherheitsniveaus.

Große Institutionen mit komplexen IT-Landschaften können durch weitreichende Automatisierungsmöglichkeiten und die nahtlose Integration mit bestehenden Management- und Sicherheitssystemen erhebliche Effizienzgewinne erzielen. Die Methodik unterstützt verteilte Zuständigkeiten und ist auf große Informationsverbünde anwendbar.

Die Methodik-GS++ ist branchenübergreifend konzipiert und berücksichtigt sowohl die Anforderungen der öffentlichen Verwaltung als auch der Wirtschaft.

1.3 Konzeptstruktur

Das vorliegende Dokument stellt eine Basisversion mit allen notwendigen und relevanten Grundinformationen der Methodik-GS++ dar und bietet somit eine Anleitung, ein ISMS für die jeweilige Institution aufzubauen und fortzuentwickeln.

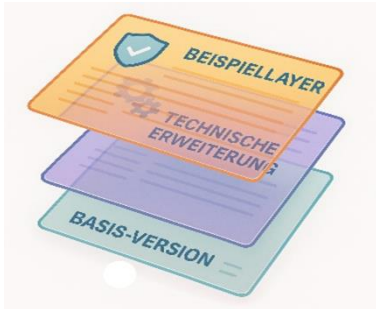


Abbildung 1 Layer

Dieses Basisdokument kann in Kombination mit weiteren Layern (siehe Abbildung 1), welche als eine Ergänzung einzelner Teilaspekte der Basisversion zu sehen sind, verwendet werden. Jeder Layer betrachtet dabei einen ganz spezifischen Aspekt der Erweiterung. So wird der Technik-Layer konkrete Informationen zum Umgang mit Anforderungspaketen auf Basis der in OSCAL vorhandenen Techniken erläutern. Die Kombination der Basisversion mit dem Technik-Layer soll die Anwendung der Methodik-GS++ mittels Blaupausen verständlich beschreiben. Zusätzlich zum Technik-Layer wird ein Beispiel-Layer einzelne Passagen der Basisversion mit Erläuterungen und Beispielen hinterlegen, um für Verständlichkeit in unterschiedlichen Kontexten zu sorgen. Zusätzlich sind weitere Layer z.B. ein Audit-Layer angedacht.

Neben diesen Layer-Dokumenten, wird es weitere ergänzende Dokumente und Hilfsmittel geben. Hierzu zählen u.a. das Dokument zur Risikobetrachtung, das Curriculum für Schulungen und Migrationsleitfäden.

1.4 Überblick über den Sicherheitsprozess nach GS++

Die Methodik-GS++ enthält folgende Prozessschritte, die jeweils Praktiken in dem Anwenderkatalog entsprechen:

- Prozessschritt 1 – Erhebung und Planung – (Plan, Praktik: Governance und Compliance)
- Prozessschritt 2 – Anforderungsanalyse (Plan, Praktik: Strukturmodellierung)
- Prozessschritt 3 – Realisierung (Do, Praktik: Umsetzung)
- Prozessschritt 4 – Überwachung (Check, Praktik: Monitoring und Evaluation)
- Prozessschritt 5 – kontinuierliche Verbesserung (Act, Praktik: Verbesserung)

Folgende Abbildung gibt einen Überblick über die Prozessschritte der Methodik-GS++ und die zugehörigen ISMS-Praktiken.

Prozessschritt 1	Prozessschritt 2	Prozessschritt 3	Prozessschritt 4	Prozessschritt 5
Erhebung & Planung	Anforderungsanalyse	Realisierung	Überwachung	Kontinuierliche Verbesserung
(Bezug zu Praktik Governance & Compliance)	(Bezug zu Praktik Strukturmodellierung)	(Bezug zu Praktik Umsetzung)	(Bezug zu Praktik Monitoring & Evaluation)	(Bezug zu Praktik Verbesserung)
- Kontext der Institution - Analyse interessierter Parteien - Geltungsbereich - Sicherheitsleitlinie - Compliance-Management - Sicherheitsorganisation und Rollen - Dokumentation und Kommunikation - Freigabe der Vorgehensweise - Festlegung des Risikomanagements	- Informationsverbund: Definition und Abgrenzung - Schutzbedarfsfeststellung - Anforderungspaket - ISMS-Anforderungen des Informationsverbundes - Asset-Modellierung - Verpflichtungen - Anforderungsergänzungen - Risikobetrachtung (inkl. Wirksamkeitsprüfung) - Gestaltungsentscheidungen	- Überprüfung des Umsetzungsstatus - Bewertung fehlender Umsetzungen - Umsetzungsplanung und Priorisierung - Zuständigkeiten und Fristen - Freigaben und Ausnahmen - Fortschrittsverfolgung - Wahrung der Compliance in der Umsetzung	- Leistungsbewertung des ISMS - Überwachung der Compliance - Auditprogrammplanung und -durchführung - Bewertung und Auditberichte - Managementbewertung - Monitoringmethoden und -tools - Verifikation der Anforderungen	- Umgang mit Nicht-Konformitäten - Identifikation von Verbesserungen - Korrektur- und Verbesserungsvorschläge - Korrektur- und Verbesserungsplan - Akzeptanz - Bewertung erreichter Verbesserungen - Behandlung von Compliance-Verstößen
PLAN		DO	CHECK	ACT

Abbildung 2 Überblick über die Schritte des Sicherheitsprozesses der Methodik-GS++

1.4.1 Überblick Prozessschritt 1 – Erhebung und Planung

Der Prozessschritt 1 ermöglicht, dass Informationssicherheitsstrategien mit den übergeordneten Zielen der Institution und regulatorischen Anforderungen im Einklang stehen. Er vereint die strategische Steuerung der Informationssicherheit mit der systematischen Identifikation und Integration externer sowie interner Themen bzw. Erwartungen.

Dieser Prozessschritt definiert den strategischen Rahmen für die Informationssicherheit und legt die Ziele der Informationssicherheit fest. Die Einbindung der Institutionsleitung in wichtige Entscheidungen zur Informationssicherheit ist gewährleistet und stellt sicher, dass alle relevanten gesetzlichen, regulatorischen und vertraglichen Vorgaben identifiziert und berücksichtigt werden. Die Institutsleitung ist somit verantwortlich für die Entscheidungen zur Informationssicherheit.

Nach der Festlegung des Geltungsbereiches werden zunächst die für den Geltungsbereich des ISMS relevanten Geschäftsprozesse identifiziert. Diese werden anschließend ihrer Kritikalität nach priorisiert.

Während der Prozessschritt 1 – „Erhebung und Planung“ die strategische Ausrichtung und die Anforderungen definiert, übernehmen die Prozessschritte 2 und 3 (Anforderungsanalyse und Realisierung) die konkrete Ausgestaltung.

1.4.2 Überblick Prozessschritt 2 – Anforderungsanalyse

Der Prozessschritt 2 bildet die Grundlage für eine systematische Analyse der Informationssicherheit einer Institution. Die Prozessschritte bauen aufeinander auf, können aber iterativ oder parallel abgearbeitet werden, wenn der Prozess einmal initial durchlaufen wurde.

Ziel ist es, ein individuelles Anforderungspaket für den Informationsverbund zu generieren. Mit der Zuordnung einzelner Praktiken und Zielobjektkategorien erfolgt eine Auswahl von Anforderungen auf der Grundlage der zuvor ermittelten Geschäftsprozesse und zugehöriger Assets. Eine Erweiterung des Anforderungspakets durch spezifische Anforderungen ist möglich und erhöht das Sicherheitsniveau durch individuelle zusätzliche Anforderungen und Maßnahmen. Für diese Anforderungen ist eine gesonderte Risikobetrachtung erforderlich.

Mit dem priorisierten Geschäftsprozess beginnend, erfolgt die Erfassung der für den jeweiligen Prozess relevanten Assets, welche anschließend den entsprechenden Zielobjektkategorien zugeordnet werden. Mit

diesen Informationen ausgestattet kann die Zusammenstellung passender Anforderungen anhand der betroffenen Praktiken und Zielobjektkategorien beginnen.

Der Prozessschritt 2 liefert essentielle Eingangsdaten für die nachgelagerten Prozessschritte und ermöglicht eine zielgerichtete und risikoorientierte Planung von Anforderungen und Maßnahmen.

1.4.3 Überblick Prozessschritt 3 – Realisierung

Der Prozessschritt 3 sorgt für die systematische Umsetzung und Dokumentation von Anforderungen bzw. der Maßnahmen, die aus der Anforderungsanalyse und der Risikobetrachtung abgeleitet wurden. Es wird sichergestellt, dass identifizierte Sicherheitsanforderungen effektiv in die organisatorischen und technischen Prozesse integriert werden.

Die Realisierung umfasst die detaillierte Planung incl. Priorisierung von Maßnahmen, die Festlegung von Zuständigkeiten und Zeitplänen sowie die Bereitstellung notwendiger Ressourcen. Zudem beinhaltet sie die Nachverfolgung der Umsetzung und die Dokumentation der erfüllten Anforderungen und umgesetzten Maßnahmen.

Während die Anforderungsanalyse die notwendigen Anforderungen identifiziert und die Überwachung die Wirksamkeit der Maßnahmen überprüft, konzentriert sich Prozessschritt 3 (Realisierung) auf die effiziente und effektive Umsetzung der erforderlichen Maßnahmen.

1.4.4 Überblick Prozessschritt 4 – Überwachung

Der Prozessschritt 4 stellt durch regelmäßige Überwachung und systematische Bewertung sicher, dass die implementierten Anforderungen wirksam sind und die Sicherheitsziele der Institution erreicht werden. Er liefert Erkenntnisse über das aktuelle Niveau der Informationssicherheit und identifiziert Verbesserungspotentiale.

Im Rahmen dieses Prozessschrittes werden regelmäßige Audits, kontinuierliches Monitoring von Sicherheitsereignissen sowie periodische Überprüfungen und Bewertungen des ISMS durchgeführt.

Die Ergebnisse dieses Prozessschrittes fließen direkt in den Prozessschritt 5 ein, wo konkrete Maßnahmen zur Behebung identifizierter Mängel und zur kontinuierlichen Verbesserung des ISMS abgeleitet werden.

1.4.5 Überblick Prozessschritt 5 – kontinuierliche Verbesserung

Der Prozessschritt 5 gewährleistet die kontinuierliche Weiterentwicklung und Optimierung des ISMS. Er nutzt die Erkenntnisse aus dem Monitoring und der Evaluation insbesondere des Audits, um die Wirksamkeit der Maßnahmen zu erhöhen.

Die kontinuierliche Verbesserung umfasst die Planung und Umsetzung von Korrektur- und Verbesserungsmaßnahmen. Ziel ist es, eine kontinuierliche Verbesserung zu etablieren, damit flexibel auf neue Bedrohungen und veränderte Rahmenbedingungen reagiert werden kann.

Der Prozessschritt 5 gibt Impulse für Verbesserungen und Weiterentwicklung des ISMS. Er stellt sicher, dass das ISMS dynamisch bleibt und sich an veränderte Anforderungen und Bedrohungen anpasst.

1.4.6 Überblick PDCA-Zyklus

Alle 5 Prozessschritte der Methodik-GS++ durchlaufen zyklisch einen Kreislauf zur kontinuierlichen Verbesserung bestehend aus den Phasen PLAN, DO, CHECK, ACT:

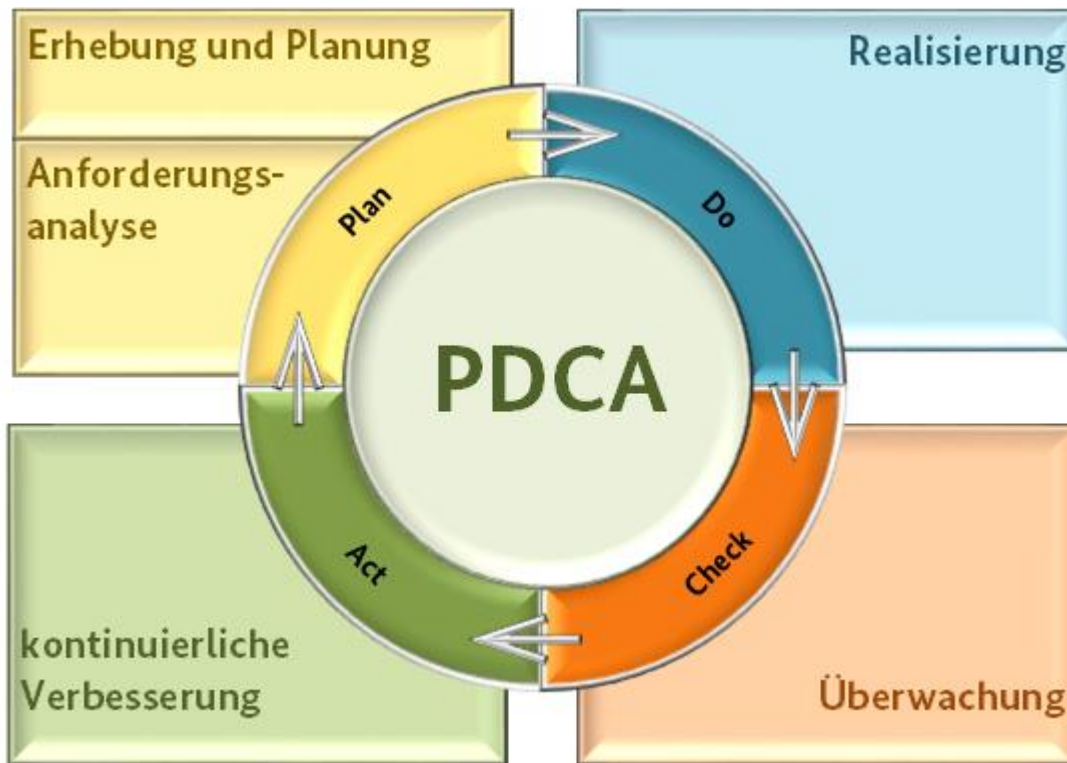


Abbildung 3 Aufteilung der Prozessschritte im PDCA-Zyklus

2 Prozessschritt 1 – Erhebung und Planung

Die Erhebung und Planung bilden das Fundament der Methodik. In diesem Prozessschritt werden die organisatorischen und rechtlichen Rahmenbedingungen für das Informationssicherheitsmanagement geschaffen. Im Fokus steht dabei die Verankerung der Informationssicherheit in der Institution durch die Festlegung klarer Strukturen, Rollen und Zuständigkeiten.

Auf der Basis des Managementrahmens, welcher sich aus den Zielen, Leitlinien, Rollen, Verantwortlichkeiten, Dokumentationen und dem kontinuierlichem Verbesserungsprozess ergibt, wird der Geltungsbereich des ISMS festgelegt.

Als Ergebnis dieses Prozessschrittes liegt eine organisatorische und strategische Grundlage vor, auf der die weiteren Prozessschritte aufbauen können. Die getroffenen Entscheidungen und geschaffenen Strukturen prägen maßgeblich die Ausrichtung und Wirksamkeit des gesamten ISMS der Institution.

Ziel ist ein Verständnis über Zweck und Grenzen des zu betrachtenden Geltungsbereiches und eine sinnvolle und eindeutige Abgrenzung des ISMS.

2.1 Festlegung des Kontextes der Institution

Die Festlegung des Kontextes der Institution bildet den Ausgangspunkt für die Gestaltung eines ISMS und ist eine erste Einordnung des Kontextes. Dieser Prozess umfasst die systematische Analyse und Dokumentation aller internen und externen Faktoren, die einen Einfluss auf die Informationssicherheitsziele und -strategie der Institution haben.

Der externe Kontext umfasst eine Vielzahl von Faktoren, die von außen auf die Institution einwirken:

- Gesellschaftliche und kulturelle Faktoren, die die Erwartungen an die Institution prägen
- Rechtliche und regulatorische Rahmenbedingungen auf nationaler und internationaler Ebene
- Technologische Entwicklungen und deren Auswirkungen auf die Informationssicherheit
- Wirtschaftliche Bedingungen im relevanten Marktumfeld sowie auch im geopolitischen Umfeld
- Auswirkungen des Klimawandels auf die Infrastruktur und den Betrieb

Der interne Kontext bezieht sich auf die institutionseigenen Faktoren:

- Institutionsstrategien, Werte und Institutionsziele
- Institutionsstruktur mit Hierarchien, Abteilungen und Zuständigkeitsbereichen
- Etablierte Prozesse und Arbeitsabläufe
- Vorhandene IT-Infrastruktur und Informationssysteme
- Institutionskultur und Einstellungen zur Sicherheit

Die systematische Analyse und Dokumentation des Kontextes schafft ein umfassendes Verständnis der Rahmenbedingungen und liefert wichtige Erkenntnisse für das ISMS. Sie hilft bei der Identifikation von Risiken und stellt sicher, dass das ISMS auf die individuellen Gegebenheiten der Institution abgestimmt ist.

2.2 Implementierung des Compliance-Managements

Ein gut strukturiertes Compliance-Management stellt sicher, dass gesetzliche und vertragliche Vorgaben nicht nur bekannt sind, sondern auch bei der Sicherheitskonzeption berücksichtigt werden. Dies minimiert Compliance-Risiken und schafft gleichzeitig Transparenz über die externen und internen Anforderungen, die das ISMS erfüllen muss.

Nach Möglichkeit sollte ein ganzheitliches Compliance-Management für die Institution etabliert sein.

Jedoch müssen mindestens die Compliance-Verpflichtungen, welche die Informationssicherheit und das ISMS betreffen, erfasst werden.

Grundlage für eine wirksame Umsetzung ist die systematische Erfassung der informationssicherheitsrelevanten Compliance-Anforderungen, andere regulatorische Bereiche bleiben in dieser Betrachtung unberücksichtigt.

Es sind ggf. Anforderungen aus den Bereichen, welche die Informationssicherheit und das ISMS im weitesten Sinne betreffen, zu berücksichtigen:

- Rechtskataster, Gesetze und Anforderungskataloge sollten analysieren werden.
- Gesetzliche Verpflichtungen, welche die Verarbeitung von Informationen durch die Institution betreffen, sollten dokumentiert werden.
- Zuständige Compliance Stellen oder vergleichbare Ansprechpartner sollten angehört werden.
- Vertragliche Verpflichtungen sollten zusammengestellt werden.

Vertragliche Verpflichtungen umfassen alle Pflichten, die sich aus rechtlich bindenden Vereinbarungen ergeben, unabhängig davon, ob diese als Vertrag bezeichnet werden oder nicht (hierzu zählen unter anderem Dienstleistungsverträge, Lizenzvereinbarungen, Service Level Agreements (SLAs) und Vertraulichkeitsvereinbarungen).

Die systematische Erfassung und Verwaltung von Compliance-Verpflichtungen für Informationssicherheit bilden die Grundlage für deren wirksame Umsetzung und kontinuierliche Überwachung.

2.3 Analyse der interessierten Parteien

Die Analyse der interessierten Parteien (Stakeholder) identifiziert systematisch alle Personen, Gruppen oder Institutionen, die ein berechtigtes Interesse an der Informationssicherheit der Institution haben oder von dieser betroffen sind. Das Verständnis ihrer Anforderungen, Erwartungen und potentiellen Einflüsse ist entscheidend für die Ausrichtung und Akzeptanz des ISMS. Auch die interessierten Parteien können Anforderungen in Bezug auf den Klimawandel haben, die zu berücksichtigen sind.

Ein Verfahren zur Ermittlung der interessierten Parteien und ihrer Bedürfnisse und Erwartungen an das ISMS muss festgelegt und durchgeführt werden.

Dabei sind folgende Aspekte u.a. zu berücksichtigen:

- Externe interessierte Parteien wie z.B. Kunden, Dienstleister, Geschäftspartner, Gesetzgeber, Aufsichtsbehörden und die Öffentlichkeit identifizieren,
- interne interessierte Parteien wie Institutionsleitung, Mitarbeitende, Führungskräfte und Personalvertretungen berücksichtigen,
- die spezifischen Anforderungen und Erwartungen jeder interessierten Partei systematisch erfassen,
- die Relevanz und Priorität der identifizierten Anforderungen bewerten und
- in Abstimmung mit der Institutionsleitung festlegen, welche dieser Anforderungen als verbindliche Verpflichtungen in das ISMS aufgenommen werden.

Die Analyse der interessierten Parteien bildet eine wichtige Grundlage für die Ausgestaltung des ISMS. Sie trägt dazu bei, dass das ISMS nicht nur technische Aspekte, sondern auch die vielfältigen organisatorischen und menschlichen Faktoren berücksichtigt, die für den Erfolg der Informationssicherheit maßgeblich sind. Die regelmäßige Überprüfung und Aktualisierung dieser Analyse stellt sicher, dass das ISMS relevant und wirksam bleibt, auch wenn sich die Stakeholder-Landschaft verändert.

2.4 Entwicklung der Informationssicherheitsleitlinie

Die Informationssicherheitsleitlinie definiert die grundlegende Ausrichtung und die Ziele der Informationssicherheit in der Institution. Sie stellt die Verbindung zwischen den übergeordneten Institutionszielen und den Anforderungen des Anforderungskataloges her und schafft einen verbindlichen Rahmen für alle Aktivitäten im Bereich der Informationssicherheit.

Insbesondere werden hier die Verpflichtung und Verantwortung der Institutionsleitung festgelegt.

Es sind z.B. folgende Aspekte zu berücksichtigen:

- Festlegung von Zielen für die Informationssicherheit

Auf Basis der identifizierten Rahmenbedingungen sollten, sofern machbar, konkrete und messbare Ziele – also spezifisch, messbar, erreichbar, relevant und zeitlich definiert (SMART-Methode) – für die Informationssicherheit definiert werden. Diese Ziele sollten einen klaren Bezug zu den Zielen der Institution aufweisen und die Anforderungen der interessierten Parteien berücksichtigen.

- Festlegung einer Sicherheitsstrategie

Eine grundlegende Strategie zur Erreichung der definierten Ziele für die Informationssicherheit muss verankert werden. Sie beschreibt den übergeordneten Ansatz und die Prinzipien. Die Sicherheitsstrategie legt fest, wie die Organisation die Ziele erreichen möchte. Diese Strategie ist mit der Institutionsleitung zu definieren und von dieser freizugeben.

- Verpflichtung der Institutionsleitung

Die Verpflichtung der Institutionsleitung zur Informationssicherheit sollte verankert werden. Diese Verpflichtung umfasst die Übernahme der Gesamtverantwortung, die Bestätigung und Überwachung der Informationssicherheitsziele im Hinblick auf die Institutionsziele sowie die aktive Förderung des ISMS. Die Förderung des ISMS erfolgt durch die aktive Beteiligung an Führungsentscheidungen, Bestätigung der Sicherheitsorganisation, die Unterstützung bei der Integration des ISMS, die Bereitstellung angemessener finanzieller und personeller Ressourcen sowie die Förderung der kontinuierlichen Verbesserung.

- Festlegung und Freigabe einer Informationssicherheitsleitlinie

Eine für die Institution passende Informationssicherheitsleitlinie zur Informationssicherheit muss erstellt werden. Diese Leitlinie sollte die Gesamtverantwortung und Verpflichtung der Institutionsleitung, die Informationssicherheitsziele, die Informationssicherheitsstrategie, die Benennung der Rollen und Zuständigkeiten sowie die Verpflichtung zur kontinuierlichen Verbesserung enthalten. Die Freigabe der Informationssicherheitsleitlinie durch die Institutionsleitung muss dokumentiert werden, beispielsweise durch eine formelle Unterschrift.

Die Informationssicherheitsleitlinie ist ein zentrales Dokument, welches an alle Mitarbeitenden kommuniziert werden muss. Sie dient als Orientierung für alle sicherheitsrelevanten Entscheidungen und Aktivitäten und fördert ein gemeinsames Verständnis der Bedeutung und Ausrichtung der Informationssicherheit.

2.5 Festlegung des Geltungsbereichs

Die Festlegung des Geltungsbereichs bildet die Grundlage für die Einführung und Weiterentwicklung des ISMS.

Der Geltungsbereich beschreibt, in welchen Bereichen und für wen das ISMS gilt. Er legt den formalen und organisatorischen Umfang (Scope) fest, in dem das ISMS angewendet wird. Damit definiert er die Grenzen der institutionellen Verantwortung für Informationssicherheit. Der Geltungsbereich wird auf Grundlage des institutionellen Kontextes, der gesetzlichen, regulatorischen und vertraglichen Anforderungen (insbesondere der interessierten Parteien) sowie der strategischen Ziele der Institution festgelegt. Er umfasst

alle relevanten Institutionseinheiten, Geschäftsprozesse, Standorte und Systeme, die im Rahmen des ISMS betrachtet werden sollen.

Wichtig ist, dass die zu betrachtenden Geschäftsaufgaben und -prozesse in dem Geltungsbereich komplett enthalten sind.

Bei der Festlegung des Geltungsbereiches sind insbesondere folgende Fragen zu klären:

Formale und organisatorische Abgrenzung:

- Welche Institutionsbereiche, Geschäftsprozesse und Tätigkeiten gehören zum Geltungsbereich?
- Welche interessierten Parteien gehören zum Geltungsbereich?

Infrastrukturelle Abgrenzung:

- Welche Standorte und Systeme liegen innerhalb des Geltungsbereichs?
- Welche externen Partner oder Dienstleister sind in das ISMS einzubeziehen?
- Welche Bereiche sind bewusst nicht Bestandteil des Geltungsbereichs?

Der Geltungsbereich des ISMS ist verbindlich zu dokumentieren und von der Institutionsleitung zu genehmigen.

Eine eindeutige Definition des Geltungsbereichs ist notwendig, um den Anwendungsrahmen des ISMS transparent darzustellen und die nachfolgenden Schritte, insbesondere die Festlegung des Informationsverbunds, gezielt durchführen zu können.

2.6 Prozess der Informationssicherheitseinstufung

Die Informationssicherheitseinstufung dient der systematischen Identifikation des Schutzbedarfs von Geschäftsprozessen und verarbeiteten Informationen. Dies bedeutet, dass der Schutzbedarf der Informationen eingestuft wird, was sich dann auf die Geschäftsprozess, in denen diese verarbeitet werden, überträgt. Der prozessorientierte Ansatz stellt die Verbindung zwischen Geschäftsprozessen und Informationen in den Vordergrund.

Das Vorgehen bei der Informationssicherheitseinstufung umfasst folgende Teilschritte:

1. Identifizierung der Geschäftsprozesse und der darin verarbeiteten Informationen.
2. Identifizierung des Schutzbedarfs der Geschäftsprozesse in Bezug auf die Informationen, anhand der Kritikalität von Auswirkungen auf die Institutionsziele.

Die Informationssicherheitseinstufung dient als Grundlage für die Identifikation von kritischen Geschäftsprozessen.

Bei der Betrachtung der kritischen Geschäftsprozesse, die für den Geltungsbereich des ISMS relevant sind, kann auf bestehende Organigramme, Prozesslandkarten und Managementsysteme zurückgegriffen werden. Dabei sind sowohl die relevanten Kernprozesse als auch deren Hilfsprozesse zu betrachten.

Besteht noch keine Prozessübersicht in der Institution, so können die technischen und organisatorischen Praktiken als Ausgangsvorschlag für relevante Hilfsprozesse herangezogen werden.

2.7 Sicherheitsorganisation und Rollen

Eine effektive Sicherheitsorganisation mit definierten Rollen und Zuständigkeiten ist die organisatorische Grundlage eines erfolgreichen ISMS. Sie stellt sicher, dass alle Aspekte der Informationssicherheit angemessen abgedeckt und mit den notwendigen Ressourcen (personell und finanziell) und Kompetenzen ausgestattet sind.

Es sind folgende Aspekte zu berücksichtigen:

- Festlegung von Rollen und Zuständigkeiten

Die Rollen im Rahmen des ISMS müssen mit den notwendigen Qualifikationen, Aufgaben und Kompetenzen festgelegt und zugewiesen werden. Eine zentrale Rolle ist dabei der „Informationssicherheitsbeauftragte“ (ISB), dessen Position klar zu definieren ist. Die Rolle des ISB muss organisatorisch unabhängig sein und sollte direkt der Leitungsebene unterstellt werden. Zur Vermeidung von Interessenskonflikten sollte der ISB nicht unter dem IT-Leiter verortet werden.

Für alle relevanten Rollen müssen Stellvertreterregelungen etabliert werden, um eine kontinuierliche Handlungsfähigkeit zu gewährleisten.

- Vermeidung von Interessenskonflikten

Bei der Festlegung von Aufgaben und Zuständigkeiten müssen Maßnahmen zur Vermeidung von Interessenskonflikten verankert werden. Insbesondere ist die Zuordnung konkurrierender Rollen (z. B. ausführender und prüfender oder freigebender Rollen) zu vermeiden.

- Sicherstellung der Qualifikation

Ein Verfahren zur Sicherstellung der Qualifikation von Rollen- und Verantwortungsträgern, im Rahmen des ISMS muss, verankert werden. Für jeden Rollen- und Verantwortungsträger müssen die erforderlichen Anforderungen und Fähigkeiten festgelegt sein.

- Festlegung einer Sicherheitsorganisation

Die Sicherheitsorganisation für die Institution muss mit den festgelegten Rollen, Zuständigkeiten sowie relevanten Gremien verankert werden. Ziel ist es, alle relevanten Bereiche eines ISMS sowie die wichtigen Schnittstellen zu anderen Bereichen vollständig und wirksam in der Institution abzubilden.

Der Aufbau der Sicherheitsorganisation sollte, bspw. in der Informationssicherheitsleitlinie, in Form eines Organigramms oder einer ähnlichen Darstellung visualisiert und hinterlegt werden. Die Beziehungen zwischen den verschiedenen Rollen, ihre Zuständigkeiten, Verantwortlichkeiten und Berichtswege sind klar darzustellen. Dies dient als Referenz für alle Mitarbeitende und unterstützt die effektive Kommunikation und Koordination in Sicherheitsfragen.

2.8 Dokumentation und Kommunikation

Eine strukturierte Dokumentation und effektive Kommunikation sind wesentliche Elemente eines funktionierenden ISMS. Sie gewährleisten, dass alle relevanten Informationen verfügbar, aktuell und für die jeweiligen Zielgruppen zugänglich sind. Das Thema Dokumentation und Kommunikation ist oft ein übergeordnetes Thema in einer Organisation. Das ISMS sollte sich daran anlehnen bzw. kann sich im Optimalfall der übergeordneten Dokumentations- und Kommunikationsprozesse komplett bedienen. Durch die Maschinenlesbarkeit der GS++ Anforderungen wird eine umfangreiche Digitalisierung der Dokumentation, welche in eine Automatisierung übergehen kann, unterstützt.

Es sind folgende Aspekte zu berücksichtigen:

- Verankerung eines Verfahrens zum Kommunikationsmanagement

Die relevanten Vorgaben und Verfahren zur internen und externen Kommunikation müssen verankert werden. Für die relevante Kommunikation im Rahmen eines ISMS sind die Eckpunkte (Wer, Was, Wann, Wo und Warum) festzulegen. Dies beinhaltet die Identifikation der relevanten Kontakte sowie die Festlegung von Zuständigkeiten für die Kommunikation. Ein besonderer Fokus liegt auf dem externen Austausch zur Informationssicherheit, um andere Perspektiven wahrzunehmen und von Erfahrungen zu profitieren.

- Kommunikation bei sicherheitsrelevanten Projekten

Der ISB oder anderen Rolle im ISMS-Team werden in sicherheitsrelevanten Projekten, wie beispielsweise bei der Einführung eines neuen Systems oder einer neuen Software, eingebunden. Es wird festgelegt, zu welchen Zeitpunkten eine Beteiligung des ISBs erfolgen soll.

- Dokumentenlenkung

Ein Verfahren zur Lenkung mindestens aller für das ISMS relevanten Dokumente muss eingerichtet und verankert werden. Ziel dieses Verfahrens ist die Sicherstellung der Nachvollziehbarkeit über den gesamten Lebenszyklus. Dies beinhaltet die Erstellung bzw. Übernahme der Dokumente mit Titel, Autor, Dokumenteneigentümer, Sicherheitsklassifikation, Erstelldatum sowie einheitlichen Formaten. Weiterhin umfasst es die Steuerung mit einem Änderungsmanagement (Versionierung), einer einheitlichen Veröffentlichung, einer angemessen geschützten Ablage und ggf. auch Archivierung sowie einer kontrollierten Rücknahme veralteter Dokumente.

Eine strukturierte Dokumentation und zielgerichtete Kommunikation unterstützen nicht nur die Compliance, sondern fördern auch das Bewusstsein für Informationssicherheit in der Institution und erleichtern die kontinuierliche Verbesserung des ISMS. Sie sind daher unverzichtbare Komponenten eines wirksamen Governance- und Compliance-Frameworks.

2.9 Festlegung und Freigabe der Vorgehensweise

Um das ISMS wirksam umzusetzen, müssen die Verfahren des ISMS klar dokumentiert und auf die Größe sowie Komplexität der Institution abgestimmt sein.

Im Folgenden werden die zentralen Themenfelder beschrieben, die für ein funktionierendes ISMS berücksichtigt werden müssen:

- Vorgehensweisen und Regelungen

Die Verfahren des ISMS sowie die Zuständigkeiten sind in geeigneter Form z.B. im Managementreport nachvollziehbar abzubilden. Dabei erfolgt die Dokumentation nicht primär in statischen Textdokumenten, sondern durch die strukturierte, maschinenlesbare Erfassung und Pflege von Leitlinien, Anforderungen, Umsetzungen und Bewertungen innerhalb der eingesetzten Systeme.

Der Umfang und die Granularität dieser Abbildungen richten sich nach der Größe, Struktur und Komplexität der Institution. Die Verfahren beinhalten insbesondere die Risikobetrachtung, die Steuerung und Nachverfolgung von Änderungen im ISMS, die Verwaltung von Anforderungen und Nachweisen, die Leistungsbewertung, die Auditierung, Maßnahmen zur kontinuierlichen Verbesserung sowie reaktive Verfahren wie z.B. Sicherheitsvorfallbehandlung, Notfallmanagement.

- Freigabe von Vorgehensweisen

Die Freigabe des Prozesses der ISMS-Verfahren erfolgt durch die Institutionsleitung. Diese Freigabe muss dokumentiert werden, um Verbindlichkeit und Nachvollziehbarkeit sicherzustellen. Beispielsweise kann diese Freigabe durch die Vorlage eines Managementberichts eingeholt werden.

2.10 Initiierung des Risikomanagements

Das Risikomanagement stellt sicher, dass Risiken systematisch identifiziert, eingeschätzt, bewertet und behandelt werden. Die Festlegung einheitlicher Kriterien für Risikoeinschätzung, Risikobewertung und Risikobehandlung, sowie die Rolle des Risikoeigentümers sorgen für Transparenz und Verbindlichkeit.

Durch die Einbindung der Institutionsleitung, insbesondere bei Freigaben und der Festlegung des Schutzbedarfs, wird das Risikomanagement auf Leitungsebene verantwortet und gesteuert. Die Institutionsleitung trägt die Gesamtverantwortung für die identifizierten Risiken und deren Behandlung und stellt durch die Etablierung und Wirksamkeit des ISMS die Erfüllung ihrer rechtlichen und organisatorischen Verpflichtungen sicher. Informationssicherheit ist damit integraler Bestandteil der Leitungsverantwortung.

In einem separaten Dokument zur Risikobetrachtung werden verbindliche Vorgaben an die Risikomethodik vorgeschrieben. Die Vorgaben sind entsprechend gängiger Risikomanagement-Prozesse strukturiert.

Eine Risikobetrachtung ist insbesondere notwendig bei hohem Schutzbedarf, negativen Änderungen des Sicherheitsniveaus (d.h. herunternutzen des Sicherheitsniveau von erhöht auf normal- SdT) oder der Nicht-Umsetzung bzw. Ergänzung des Anforderungspaketes.

Zur Risikobetrachtung werden verbindliche Vorgaben an die Risikomethodik in Bezug auf die Anwendung der Methodik-GS++ vorgegeben.

Innerhalb dieses Rahmens kann die Methode zur Risikobetrachtung frei gewählt werden, sofern diese die Vorgaben des separaten Dokuments zur Risikobetrachtung erfüllt.

3 Prozessschritt 2 – Anforderungsanalyse

Die Anforderungsanalyse verknüpft die übergreifenden Rahmenbedingungen des ISMS mit den konkreten Anforderungen an die Informationssicherheit im Einzelnen, die in den methodischen, organisatorischen und technischen Praktiken zu finden sind.

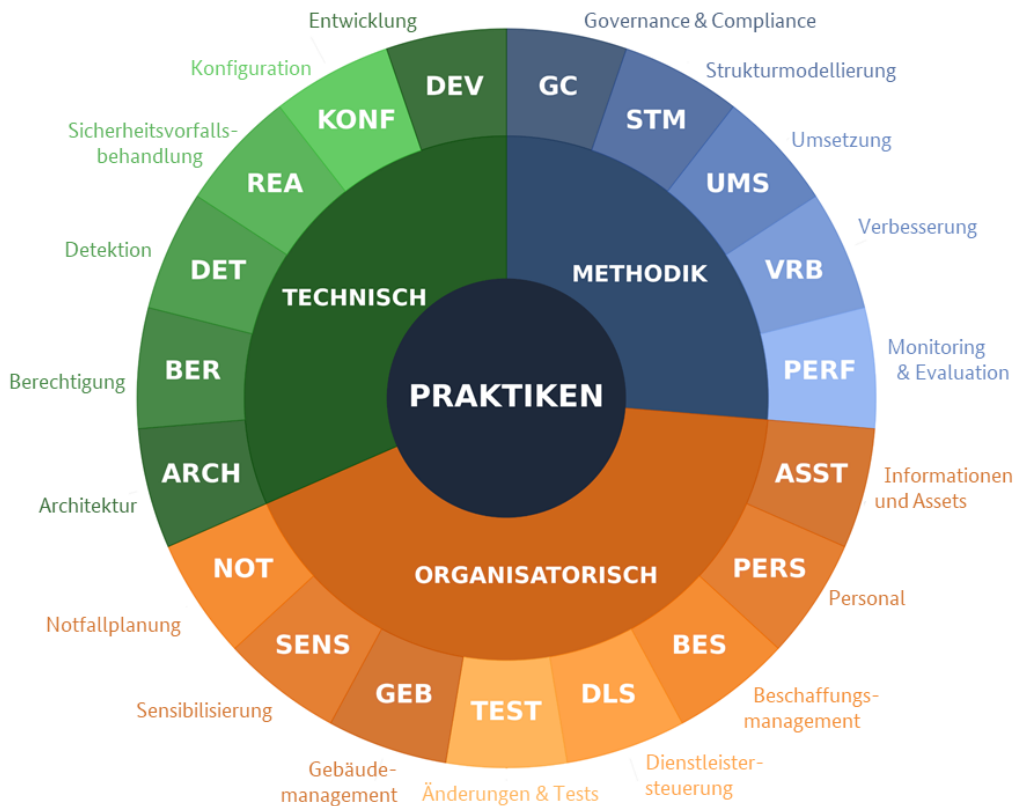


Abbildung 4 Praktiken

Ziel ist es, für den konkreten Informationsverbund und seine Assets die jeweils relevanten Anforderungen zu identifizieren und in einem Anforderungspaket zusammenzustellen. Dieses Anforderungspaket ist exakt auf den Informationsverbund zugeschnitten und bildet die Basis für die spätere Umsetzung.

Hinweis:

Bei der Erstellung des individuellen Anforderungspaketes gibt es verschiedene Wege die Anforderungen aus den Anforderungskatalogen zusammenzustellen. Je nach Größe der Institution, dem Schutzbedarf, den strategischen Zielen oder externen Vorgaben kann die Modellierung variieren.

Das im Folgenden beschriebene Verfahren ist die Standardvorgehensweise, die auch ohne weitere Hilfsmittel d.h. ohne Automatisierung durchgeführt werden kann.

Bei der Durchführung der Anforderungsanalyse (Prozessschritt 2) kann parallel vorgegangen werden.

3.1 Definition und Abgrenzung des Informationsverbunds

Die präzise Definition und Abgrenzung des Informationsverbunds ist eine grundlegende Voraussetzung für ein wirksames ISMS. Während der Geltungsbereich des ISMS den formalen Rahmen vorgibt, stellt der Informationsverbund die inhaltlich-technische Abbildung dieses Bereichs dar.

Im Rahmen der Methodik-GS++ bildet ein Informationsverbund die Einheit, für den in der Anforderungsanalyse ein Sicherheitskonzept entsteht. Im Informationsverbund werden die informationsverarbeitenden Systeme, Prozesse, Personen und Komponenten innerhalb des festgelegten Geltungsbereichs des ISMS betrachtet.

Hinweis:

Eine Nachnutzung von schon erfassten und bearbeiteten Assets in weiteren Geschäftsprozessen, aber auch bei anderen Informationsverbünden im Geltungsbereich des ISMS ist hierbei sinnvoll und erwünscht

Die Definition des Informationsverbundes erfolgt auf Basis des analysierten Kontextes (siehe 2.2) und der Anforderungen der interessierten Parteien (siehe 2.3) sowie der daraus abgeleiteten Ziele. Dabei müssen folgende Fragen beantwortet und dokumentiert werden:

- Welche organisatorischen, technischen und infrastrukturellen Anteile werden intern betrieben und welche an externe Parteien ausgelagert?

Organisatorische und personelle Abgrenzung:

- Welche Institutionsbereiche bzw. Rollen gehören zum Informationsverbund?

Technische Abgrenzung:

- Welche Anwendungen, Systeme und Netze sind Bestandteil des Informationsverbundes?
- Wo verlaufen die technischen Grenzen und wie sind Schnittstellen zu externen Systemen gestaltet?
- Welche Cloud-Dienste werden genutzt?

Infrastrukturelle Abgrenzung:

- Welche Standorte, Gebäude und Räumlichkeiten gehören zum Informationsverbund?

Zusätzlich sind die Schnittstellen des Informationsverbunds zu externen Prozessen und Systemen eindeutig zu dokumentieren, sowohl organisatorisch als auch technisch und infrastrukturell. Dies schließt auch die Schnittstellen zu anderen Informationsverbünden im Geltungsbereich des ISMS mit ein.

Eine klare und nachvollziehbare Abgrenzung des Informationsverbunds stellt sicher, dass alle relevanten Informationswerte, Strukturen und Abhängigkeiten im Rahmen der Sicherheitskonzeption erfasst werden. Sie ermöglicht eine zielgerichtete Anwendung von Maßnahmen und unterstützt die Wirksamkeit des ISMS.

3.2 Übersicht über die Erstellung eines Anforderungspakets

Das Anforderungspaket umfasst die für den betrachteten Informationsverbund und die priorisierten Geschäftsprozesse relevanten Anforderungen aus dem GS++ sowie, falls erforderlich, zusätzliche, benutzerdefinierte Anforderungen.

Das Anforderungspaket entsteht durch die Modellierung von Anforderungen auf zwei Ebenen.

Anforderungen-GS++:

- Anforderungen aus den ISMS-Praktiken
- Anforderungen mit Bezug zu einer Zielobjektkategorie
- Anforderungen ohne Bezug zu einer Zielobjektkategorie.

zusätzlichen Anforderungen:

- aus anderen Verpflichtungen
- neue ergänzende Anforderungen die nicht im GS++ enthalten sind
- für höheren Schutzbedarf
- Ergebnisse aus Risikobetrachtungen

Die folgende Grafik gibt eine Übersicht über die Anforderungsmodellierung.

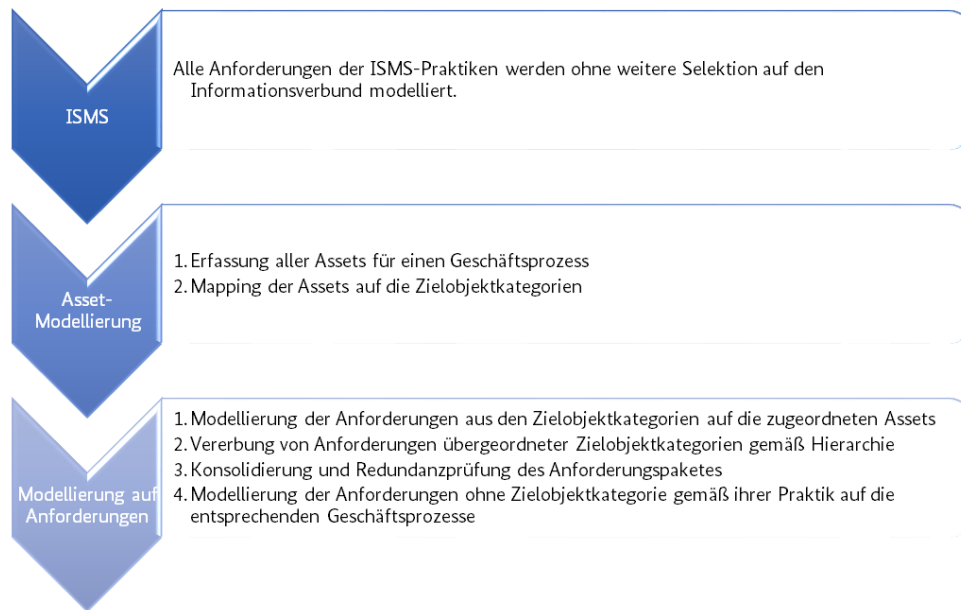


Abbildung 5 Anforderungsmodellierung

3.3 ISMS-Anforderungen des Informationsverbundes

Die Anforderungen der ISMS-Praktiken sind übergreifend und keiner einzelnen Zielobjektkategorie zugewiesen. Sie bauen auf den PDCA-Zyklus des Managementsystems auf und gelten deshalb einmalig für den gesamten Informationsverbund.

1. Alle Anforderungen der ISMS-Praktiken werden ohne weitere Selektion auf den Geltungsbereich und den Informationsverbund modelliert.
2. Sie werden als „verbundweite Anforderungen“ im Anforderungspaket geführt, da sie Governance-, Steuerungs-, Kontroll- und Verbesserungsprozesse definieren.

Die ISMS-Anforderungen aus den fünf Praktiken Governance und Compliance, Strukturmodellierung, Umsetzung, Monitoring und Evaluation sowie Verbesserung bilden den Kern des Anforderungspaketes für den Informationsverbund.

3.4 Asset-Modellierung

Die Asset-Modellierung ist der zentrale Schritt, um den zuvor festgelegten Informationsverbund strukturiert und nachvollziehbar in seinen sicherheitsrelevanten Bestandteilen zu betrachten. Ziel ist es, die für den betrachteten Geschäftsprozess relevanten Assets zu identifizieren, zu dokumentieren und so zu modellieren, dass daraus automatisiert oder manuell passende Anforderungen abgeleitet werden können.

Die Asset-Modellierung fokussiert auf jene Assets, die im Rahmen der priorisierten Geschäftsprozesse Informationen verarbeiten, speichern, übertragen oder deren Schutz unterstützen.

Sie stellt sicher, dass Anforderungen nicht abstrakt, sondern entlang konkreter Objekte und Verantwortlichkeiten zugeordnet werden können.

Die Asset-Modellierung erfolgt in folgenden Teilschritten:

1. Erfassung aller relevanten Assets
2. Zuordnung der Assets auf eine oder mehrere passende Zielobjektkategorie (Zielobjektmapping)

Ergebnis dieses Schritts ist eine Zuordnung aller Assets zu entsprechenden Zielobjektkategorien, die als Grundlage für die Anforderungsmodellierung und die spätere Umsetzung dient.

3.4.1 Erfassung relevanter Assets

Für die Modellierung der Anforderungen aus dem Anforderungskatalog werden die für den jeweiligen Geschäftsprozess relevanten Assets identifiziert und dokumentiert.

Im ersten Durchgang des PDCA-Zyklus ist es ausreichend, die Assets zu erfassen, die für den wichtigsten Geschäftsprozess erforderlich sind. Weitere Geschäftsprozesse und zugehörige Assets können iterativ in nachfolgenden Zyklen oder parallel ergänzt werden.

Durch die zyklische und somit wiederkehrende Abarbeitung der einzelnen Prozessschritte dieses Dokumentes wird die Betrachtung der vollständigen Asseterfassung innerhalb des Geschäftsprozesses erreicht.

Relevante Assets können insbesondere sein:

- Information
- Systeme und Anwendungen (System Assets)
- Netz- und Kommunikationskomponenten
- Infrastrukturelle und physische Assets
- Personelle und organisatorische Assets

Für die Analyse kann auf vorhandene Assetdaten/-register und digitale erfasste Systemdaten zurückgegriffen werden.

Für jedes Asset sollten folgende Informationen festgehalten werden:

- eindeutige Bezeichnung/ID
- kurze Beschreibung und Zweck
- Zuordnung zu Geschäftsprozess(en)
- verantwortliche Rolle bzw. Asset-Owner
- ggf. Standort bzw. logische Einordnung (Netz, Anwendungskontext etc.)
- ggf. vorhandene Abhängigkeiten zu anderen Assets

Die Erfassung ist so zu gestalten, dass neue Assets oder Änderungen am Bestand jederzeit nachgetragen werden können. Damit wird die Modellierung konsistent erweitert und gepflegt.

3.4.2 Mapping der Assets auf die Zielobjektkategorien

Jedes der relevanten Assets wird anschließend einem oder mehreren Zielobjektkategorien zugeordnet. Dies erfolgt anhand der Definitionen der Zielobjektkategorien.

Zielobjektkategorien sind standardisierte Klassen, für die im GS++ beschriebenen Anforderungen. Durch das Mapping werden Assets damit in die Systematik des GS++ überführt.

. Für jedes Asset ist zu prüfen, welche Kategorie(n) seine Funktion und seinen Einsatz im Geschäftsprozess am besten abbilden. Dabei gelten folgende Grundsätze:

- Ein Asset kann mehreren Zielobjektkategorien zugeordnet werden, wenn es mehrere Funktionen erfüllt.
- Die Zuordnung erfolgt funktionsorientiert, nicht nur nach technischen Merkmalen. Entscheidend ist, wie das Asset im Geschäftsprozess wirkt.
- Schwer zuordenbare Assets werden im Rahmen der Risikobetrachtung analysiert, um sicherzustellen, dass auch hierfür Anforderungen bzw. Maßnahmen abgeleitet werden können.

Die Zuordnung kann toolgestützt erfolgen, wenn Zielobjektkategorien maschinenlesbar hinterlegt sind. Bei manueller Zuordnung ist die Entscheidung nachvollziehbar zu dokumentieren (z.B. durch kurze Begründung oder Verweis auf Definition der Zielobjektkategorie(n)).



Abbildung 6 Zielobjektkategorien und Vererbung

3.5 Anforderungsmodellierung auf die Assets

Bei der Modellierung der Assets auf Anforderungen des GS++ wird wie folgt vorgegangen:

1. Vererbung von Anforderungen übergeordneter Zielobjektkategorien entsprechend der Zielobjekthierarchie
2. Modellierung der Anforderung aus den Zielobjektkategorien auf die zugeordneten Assets und Erstellung des Anforderungspakets für den betrachteten Geschäftsprozess
3. Konsolidierung und Redundanzprüfung des Anforderungspakets
4. Modellierung aller weiteren benötigten Anforderungen, denen kein Zielobjektkategorie zugeordnet ist, durch Mapping der Anforderungen anhand ihrer Praktik und Prüfung auf Relevanz für den zu betrachtenden Geschäftsprozess

3.5.1 Vererbung von Zielobjektkategorien

Im nächsten Schritt werden die zuvor zugeordneten Zielobjektkategorien um diejenigen Kategorien erweitert, die in der Zielobjekthierarchie übergeordnet sind. Hintergrund ist, dass Anforderungen nicht nur auf die „Blatt-Zielobjektkategorie“ (direkt zugeordnete Zielobjektkategorien), sondern auch auf deren konzeptionelle Oberknoten wirken. Dadurch wird sichergestellt, dass übergreifende Anforderungen konsistent berücksichtigt werden.

Denn Anforderungen werden einmalig für die passende Zielobjektkategorie definiert und dann auf alle nachgeordneten Kategorien vererbt. Durch die Vererbung wird es einfacher den Umsetzungsstand und das Sicherheitsniveau über verschiedene Systeme und Anwendungen hinweg zu erfassen und zu vergleichen. Eine automatisierte Verarbeitung der Vererbungshierarchie kann den Umsetzungsaufwand erheblich reduzieren, ohne dass Themen außen vor bleiben.

Die Vererbung erfolgt entlang der Zielobjekthierarchie:

1. Für jedes zugeordnete Zielobjekt werden alle Elternknoten bis zur Wurzel einbezogen.
2. Die Vererbung ist deterministisch, da die Zielobjekthierarchie fest definiert ist.
3. Eine Automatisierung der Vererbung ist möglich und empfohlen, wenn die Hierarchie maschinenlesbar vorliegt.

Ergebnis dieses Schrittes ist eine vollständige Liste der Zielobjektkategorien je Asset, bestehend aus direkt zugeordneten Zielobjektkategorien und vererbten übergeordneten Zielobjektkategorien. Dieses Set bildet die Grundlage für die Anforderungskonsolidierung und -ergänzung um die Anforderungen ohne Zielobjektkategorie.

3.5.2 Modellierung der Anforderungen mit Bezug zu einer Zielobjektkategorie

Nun werden die Anforderungen aus dem GS++ auf die identifizierten Assets modelliert.

Den im vorherigen Schritt zugeordneten Zielobjektkategorien sind im GS++ bereits Anforderungen zugewiesen. Diese Anforderungen sind jetzt auf das jeweilige Asset anzuwenden und somit in das Anforderungspaket mit der Zuordnung zum jeweiligen Asset aufzunehmen.

Bei Anforderungen, denen zwei Zielobjektkategorien zugeordnet sind, wird die Anforderung auf die zuerst genannte Kategorie modelliert, wenn für das jeweilige Asset eine Abhängigkeit zu einem anderen Asset besteht, dass als zweites genannt wurde.

Die modellierten Anforderungen bilden das individuelle Anforderungspaket des festgelegten Informationsverbund in Bezug auf den ausgewählten Geschäftsprozess.

3.5.3 Konsolidierung und Redundanzprüfung

Wenn Anforderungen durch mehrere vererbte Zielobjektkategorien identisch auf ein Asset wirken, werden sie nur einmal geführt, jedoch mit dem Verweis auf jedes identifizierte Asset. So bleibt das Anforderungspaket schlank und umsetzbar. Redundanzen werden vermieden, aber unterschiedliche assetspezifische Umsetzungen einer Anforderung bleiben erhalten.

Ergebnis ist ein vollständiger Satz an Anforderungen pro Asset, welcher alle organisatorischen, technischen, personellen und infrastrukturellen Vorgaben enthält. Diese Anforderungen ergänzen das Anforderungspaket.

3.5.4 Modellierung der Anforderungen ohne Zielobjektkategorie

Einige technische und organisatorische Anforderungen sind keiner Zielobjektkategorie zugeordnet. Diese Anforderungen werden wie auch die Methodik-Anforderungen nur einmalig im Geltungsbereich des ISMS modelliert. Dazu werden alle Anforderungen einer Praktik, denen keine Zielobjektkategorie zugewiesen ist, den jeweiligen Geschäftsprozessen zugeordnet, welche in Kapitel 2.6 identifiziert wurden.

Für den gerade zu betrachtenden Geschäftsprozess ist dabei wie folgt vorzugehen:

1. Relevanzentscheidung je Anforderung im gerade betrachteten Geschäftsprozess:

Für jede Anforderung ohne Zielobjektkategorie wird entschieden, ob sie für den Geschäftsprozess bzw. die zugehörigen Assets erforderlich ist.

2. Zuordnung auf betroffene Geschäftsprozesse

Hierbei werden diese Anforderungen auch den federführend zuständigen Rollen (sog. Prozess-Ownern) zugewiesen.

3. Für den gerade betrachteten Geschäftsprozess nicht relevante Anforderungen ohne Zielobjektkategorie werden aus dem Anforderungspaket gestrichen. Da eine Praktik Anforderungen ohne Zielobjektkategorie enthalten kann, die zwar zu diesem Tätigkeitsbereich (Praktik) gehört, aber nicht relevant für den gerade betrachteten Geschäftsprozess ist. Dies ist mit einer Begründung, zu dokumentieren, um Nachvollziehbarkeit bei einem späteren Audit bzw. Zertifizierung zu sichern.

Diese Anforderungen bilden dann die Sicherheitsvorgaben an den jeweiligen Prozess.

3.6 Anforderungsergänzungen

3.6.1 Aufgrund anforderungsloser Assets

Falls es für Assets oder Themen im GS++ derzeit noch keine Anforderungen gibt, sollten diese von der Institution erstellt werden.

Die Anforderungsmodellierung für Assets ohne Anforderungen umfasst folgende Schritte:

1. Identifikation und Dokumentation von Assets, für die es keine Anforderungen im Anforderungskatalog des Grundschutzes gibt.
2. Es ist nachvollziehbar zu begründen, warum die Anforderungen aus dem Anforderungskatalog des Grundschutzes nicht ausreichen, um redundanten Anforderungen vorzubeugen.
3. Erstellung von neuen Anforderungen in Bezug auf die Schutzziele (Vertraulichkeit, Integrität und Verfügbarkeit), für diese Assets.
4. Erweiterung des Anforderungspakets um die neuen Anforderungen.

Die Ergebnisse dieser Anforderungsmodellierung sind individuelle und bedarfsgerechte Anforderungen für Assets, für die im Anforderungskatalog des GS++ noch keine Anforderungen zu finden sind. Die neuen Anforderungen werden als fester Bestandteil in das Anforderungspaket integriert.

Auch neu hinzugefügte Anforderungen müssen auf ein entsprechendes Risiko einzahlen, weshalb die Mitigation dieses Risikos mittels der neu hinzugefügten Anforderung nachzuweisen ist. Dies kann durch eine Risikobetrachtung erfolgen. Dabei ist jedoch folgendes zu beachten:

1. Zahlt die Anforderung auf ein Schadensszenario ein? Dann ist eine entsprechende Risikoanalyse durchzuführen.
2. Steht eine neue Anforderung in einem irgendwie gearteten Abhängigkeitsverhältnis zu einer durch das BSI vorgegebene Anforderung? Wenn ja, dann ist diese Abhängigkeit der Risikoanalyse als Input mitzugeben und dort zu betrachten sowie eine Auflösung dieser Abhängigkeit als Ergebnis der Risikoanalyse an die GS++ Methodik zurückzugeben.
3. Zahlt eine Anforderung auf kein Schadensszenario ein, so ist dies kurz darzulegen

3.6.2 Aufgrund externer Verpflichtungen

Dieser Schritt ergänzt das Anforderungspaket, um Anforderungen, die sich aus dem individuellen Compliance-Umfeld der Institution ergeben. Die Integration von externen Compliance-Verpflichtungen stellt sicher, dass alle relevanten gesetzlichen und vertraglichen Pflichten berücksichtigt werden, die erfasst wurden. Die in Prozessschritt 1 im Compliance-Management identifizierten und dokumentierten

- gesetzlichen Verpflichtungen, welche die Verarbeitung von Informationen durch die Institution betreffen
- vertraglichen Verpflichtungen mit Relevanz für die Informationsverarbeitung

bilden die Grundlage der Betrachtung.

Dabei ist wie folgt vorzugehen:

1. Identifikation von Anforderungen auf der Grundlage der externen Verpflichtungen
2. Modellierung von Anforderungen in Bezug auf diese Verpflichtung
3. Konsolidierung und Redundanzprüfung des Anforderungspakets
4. Integration dieser Anforderungen in das Anforderungspaket, soweit sie nicht bereits darin enthalten sind.

Die Integration dieser Anforderungen trägt dazu bei, dass die spätere Umsetzung aller relevanten externen Vorgaben berücksichtigt und Compliance-Risiken minimiert werden. Dies ist besonders wichtig in stark regulierten Branchen oder bei Institutionen mit komplexen vertraglichen Beziehungen.

Die Dokumentation der Compliance-Anforderungen sollte so gestaltet sein, dass Veränderungen im regulatorischen oder vertraglichen Umfeld leicht erkannt und in die Modellierung integriert werden können. Dies unterstützt die kontinuierliche Anpassung und Verbesserung des ISMS an neue Compliance-Anforderungen.

3.7 Überprüfung des gesetzten Sicherheitsniveaus

Durch die Durchführung dieses Prozessschrittes der Anforderungsanalyse für alle Geschäftsprozesse mit normalem Schutzbedarf und somit ohne zusätzlich Risikobetrachtung, erfolgt eine Modellierung der Anforderungen mit einem initiale vorgegebenem Sicherheitsniveau.

In diesem Teilschritt der Anforderungsanalyse ist es möglich die initiale Einstellung des Sicherheitsniveaus zu überprüfen und bei Bedarf, auch bei einzelnen Assets, zu ändern.

Sollte eine Erhöhung des Sicherheitsniveaus (von ‚normal (SdT)‘ auf ‚erhöht‘) erfolgen so hat dies lediglich Auswirkungen auf die Reihenfolge bei der Umsetzung der Anforderungen. Sollte hingegen eine Verringerung des initialen Sicherheitsniveaus (von ‚erhöht‘ auf ‚normal (SdT)‘) erfolgen, so ist dies mit einer Risikobetrachtung, wie im folgenden Kapitel beschrieben, zu begründen.

3.8 Durchführung der Risikobetrachtung

An dieser Stelle sieht die Methodik-GS++ den Übergang in eine separate Risikobetrachtung vor, sofern diese in den entsprechenden Absätzen dieses Dokumentes explizit gefordert wurde.

Die Risikobetrachtung nutzt die festgelegten Informationen und erfolgt nach den Vorgaben des separaten Dokuments zur Risikobetrachtung.

Die Ergebnisse der Risikobetrachtung werden als zusätzliche Anforderungen für hohen Schutzbedarf in das Anforderungspaket übernommen und entsprechend des Prozessschrittes 3 (Realisierung) weiterverwendet.

3.9 Gestaltungsentscheidungen

Durch die bisherigen Schritte wurde ein Anforderungspaket erstellt, welches grundlegend zum Informationsverbund passt. Bevor mit der Umsetzung begonnen wird, gilt es nun noch zentrale Gestaltungsentscheidungen zu treffen.

Parameter sind variabel gestaltbare Elemente innerhalb einer Anforderung, die Editoren, Auditoren und Anwendern Spielräume aufzeigen und zur automatisierten Prüfung genutzt werden können. Sie ermöglichen es, Anforderungen an spezifische Kontexte anzupassen. Sollte für eine Anforderung aus unterschiedlichen Vorgaben unterschiedliche Parametereinstellungen gefordert werden, ist immer die sicherste Einstellung zu wählen bzw. die Anforderung bezogen auf das jeweilige Asset separat zu betrachten.

3.9.1 Verteilung der führenden Zuständigkeiten

Jede Praktik enthält im Abschnitt „Grundlagen“ eine Anforderung zur Zuweisung einer Zuständigkeit zu bestimmten Rollen. Durch das Setzen dieser Parameter wird festgelegt, welche Rollen die führende Zuständigkeit für den zugeordneten Prozess erhalten.

Dies wirkt sich auch auf das Anforderungspaket aus: Hier ist die Zuständigkeit für jede Anforderung anhand ihrer Praktik erkennbar.

3.9.2 Weitere Parameter

Bei manchen Anforderungen wird es eine Auswahl an möglichen einsetzbaren Werten geben, welche durch andere Normen und Standards vorgegeben sein können.

4 Prozessschritt 3 – Realisierung

Während der Realisierung werden die zuvor identifizierten Anforderungen in die Praxis überführt. Dies umfasst sowohl die Überprüfung des aktuellen Umsetzungsstatus als auch die Planung und Realisierung noch ausstehender Anforderungen. Grundlage hierfür ist das zuvor modellierte Anforderungspaket.

Der Umsetzungsprozessschritt beinhaltet folgende Aspekte:

- Die systematische Überprüfung des Umsetzungsstatus aller Anforderungen aus dem modellierten Anforderungspaket
- Die Bewertung nicht umgesetzter Anforderungen mittels einer Risikobetrachtung entsprechend Kapitel 3.8
- Die strukturierte Planung und Priorisierung von Maßnahmen zur Erfüllung offener Anforderungen
- Die Zuweisung von Zuständigkeiten und realistischen Umsetzungsfristen
- Die Etablierung eines Freigabeverfahrens für die Umsetzungsplanung und den Umgang mit Ausnahmen
- Die systematische Nachverfolgung des Umsetzungsfortschritts und die Überprüfung der Wirksamkeit umgesetzter Maßnahmen

Das Ergebnis dieses Prozessschrittes ist die kontrollierte Realisierung des Anforderungspakets durch geeignete Maßnahmen sowie eine transparente Dokumentation des Umsetzungsstatus. Durch die klare Zuordnung von Verantwortlichkeiten und die systematische Fortschrittsverfolgung wird eine strukturierte und nachhaltige Umsetzung gewährleistet. Output dieses Prozessschritts ist der dokumentierte Umsetzungsstand sowie ein Umsetzungsplan.

4.1 Ermittlung des Umsetzungsstatus

Die Ermittlung bzw. Überprüfung des Umsetzungsstatus bildet den Ausgangspunkt der Umsetzung und dient der systematischen Erfassung des aktuellen Umsetzungsstands aller Anforderungen aus dem im Rahmen der Anforderungsanalyse erstellten Anforderungspakets. Dieser Schritt liefert ein klares Bild davon, welche Anforderungen bereits erfüllt sind und wo Handlungsbedarf besteht.

Bei der Überprüfung des Umsetzungsstatus gilt:

1. Für jede Anforderung muss der aktuelle Umsetzungsstatus vollständig überprüft werden.
2. Der Umsetzungsstatus einer Anforderung kann grundsätzlich nur „umgesetzt“ („ja“) oder „nicht umgesetzt“ („nein“) sein.
3. Eine Anforderung gilt nur als umgesetzt, wenn die Anforderung selbst umgesetzt ist, sowie alle in Abhängigkeit stehenden Anforderungen umgesetzt sind.

Für nicht umgesetzte, jedoch für den betrachteten Geschäftsprozess relevante Anforderungen (MUSS und SOLLTE), ist eine Risikobetrachtung entsprechend Kapitel 3.8 durchzuführen.

Die Überprüfung des Umsetzungsstatus sollte nach einem strukturierten Verfahren erfolgen, das eine konsistente Bewertung aller Anforderungen sicherstellt. Je nach Größe und Komplexität der Institution können unterschiedliche Methoden zum Einsatz kommen, von Interviews und Dokumentenprüfungen bis hin zu automatisierten Konfigurationsprüfungen und technischen Scans.

Der Prozessschritt 3 (Realisierung) soll für die systematische Planung, Umsetzung und Dokumentation von Maßnahmen auf Basis der Anforderungen, die in Prozessschritt 2 (Anforderungsanalyse) abgeleitet wurden, sorgen. Der Prozessschritt soll sicherstellen, dass identifizierte Sicherheitsanforderungen durch effektive Maßnahmen umgesetzt werden.

4.2 Bewertung fehlender Umsetzungen

Die Restrisikobewertung erfolgt auf Grundlage der Ergebnisse der durchzuführenden Risikobetrachtung bei Nichtumsetzung von Anforderungen aus den vorherigen Teilschritten. Eine Bewertung der durch die Risikobetrachtung zurückgelieferten Restrisiken ist ein wichtiger Schritt zur Priorisierung von Maßnahmen.

4.3 Umsetzungsplanung und Priorisierung

Die Umsetzungsplanung und Priorisierung transformiert die identifizierten Maßnahmen in einen strukturierten Umsetzungsplan. Dieser Schritt ist entscheidend, um die verfügbaren Ressourcen effizient einzusetzen und die wichtigsten Risiken vorrangig zu adressieren.

Die Umsetzungsplanung umfasst folgende Aspekte:

- Festlegung konkreter Maßnahmen für die Ergebnisse einer durchgeführten Risikobetrachtung
- Priorisierung der festgelegten Maßnahmen auf Basis der Risikobetrachtung und weiterer relevanter Faktoren wie Abhängigkeiten und Ressourcenverfügbarkeit, sowie dem Aufwand
- Berücksichtigung von Synergien zwischen Maßnahmen, die mehrere Anforderungen gleichzeitig adressieren können
- Prüfung, ob ähnliche Defizite in anderen Bereichen bestehen und gemeinsame Lösungen entwickelt werden können

Die Priorisierung der Maßnahmen sollte nach klaren Kriterien erfolgen. Es sollten folgende Elemente berücksichtigt werden:

- Eine Priorisierung der Umsetzung muss auf Basis einer geeigneten Bewertung verankert werden, wobei die Maßnahmen, die die schwerwiegendsten Risiken behandeln, höchste Priorität erhalten sollten.
- Neben der Bewertung des Risikos sollten auch Faktoren wie Umsetzungsaufwand, verfügbare Ressourcen und Abhängigkeiten in die Priorisierung einfließen.
- Auch die strategische Bedeutung für die Institutionsziele und mögliche Quick-Wins mit hoher Sichtbarkeit und Akzeptanz sollten berücksichtigt werden.

Das Verfahren zur Umsetzungsplanung sollte für die Institution angemessen sein und auf ihre eigenen Gegebenheiten und Prozesse abgestimmt sein. Für kleinere Institutionen kann eine einfachere Planung ausreichen, während größere und komplexere Institutionen ein detaillierteres Planungsverfahren benötigen.

Das Ergebnis der Umsetzungsplanung ist ein strukturierter und priorisierter Umsetzungsplan, der als Leitfaden für die systematische Verbesserung des Sicherheitsniveaus dient.

4.4 Zuständigkeiten und Umsetzungsfristen

Die eindeutige Festlegung von Zuständigkeiten, Verantwortlichkeiten und realistischen Umsetzungsfristen ist entscheidend für die erfolgreiche Realisierung des Umsetzungsplans. Dieser Schritt überführt die geplanten Maßnahmen in verbindliche Aufgaben mit klaren Verantwortlichkeiten und zeitlichen Vorgaben.

Folgende Aspekte sind zu beachten:

- Für die effektive Umsetzung sind klare Verantwortlichkeiten und realistische Zeitpläne unerlässlich.
- Die Zuständigen für die Umsetzung der Priorisierungen müssen eindeutig zugewiesen werden, wobei die zugewiesenen Personen oder Teams über die erforderlichen Kompetenzen und Ressourcen verfügen sollten.
- Für jede umzusetzende Maßnahme muss ein realistisches Zieldatum festgelegt werden, das den Umfang, die verfügbaren Ressourcen und mögliche Abhängigkeiten berücksichtigt.

- Die Zuweisung von Zuständigkeiten und Verantwortlichkeiten sollte in Abstimmung mit den betroffenen Bereichen erfolgen.
- Fristen müssen den Umfang der Maßnahme, verfügbare Ressourcen und mögliche Abhängigkeiten berücksichtigen.

Die festgelegten Zuständigkeiten, Verantwortlichkeiten und Fristen sollten in geeigneter Form dokumentiert werden, beispielsweise in einem Projektmanagement- oder Ticketsystem.

Insbesondere bei komplexeren Maßnahmen kann es sinnvoll sein, sowohl eine fachliche als auch eine operative Verantwortung zu definieren und bei Bedarf Teilaufgaben mit eigenen Verantwortlichkeiten und Fristen zu bilden.

4.5 Freigabeverfahren und Ausnahmemanagement

Die Freigabeprozesse gewährleisten die formale Absicherung von Entscheidungen und den kontrollierten Umgang mit Abweichungen von den Anforderungen.

Freigabeverfahren und Ausnahmemanagement umfassen folgende Aspekte:

- Ausnahmegenehmigungen für Compliance-Verpflichtungen müssen durch eine verantwortliche Rolle autorisiert werden
- jede Ausnahmegenehmigung muss mit einer nachvollziehbaren Begründung dokumentiert werden

Bei Zielkonflikten zwischen verschiedenen Verpflichtungen müssen diese gegeneinander abgewogen und bei Bedarf Ausnahmegenehmigungen eingeholt werden. Zur Entscheidungsfindung kann eine Folgeabschätzung (Bewertung der Konsequenz) vorgenommen werden, die die potenziellen Auswirkungen unterschiedlicher Handlungsoptionen bewertet.

Die Dokumentation von Ausnahmegenehmigungen ist besonders wichtig, um rechtlich bedeutsame Entscheidungen zur Informationsverarbeitung später nachvollziehen und gegebenenfalls anpassen zu können. Diese Dokumentation muss nicht zwingend separat erfolgen, sondern kann in bestehende Systeme wie CMDBs, Aktenverzeichnisse, Commit-Messages oder Ticketsysteme integriert werden.

Ein strukturiertes Freigabe- und Ausnahmemanagement schafft Rechtssicherheit und Transparenz und stellt sicher, dass Abweichungen von Anforderungen bewusst und kontrolliert erfolgen.

4.6 Fortschrittsverfolgung der Realisierung

Die systematische Nachverfolgung des Umsetzungsfortschritts ist entscheidend, um den Erfolg der Umsetzung zu gewährleisten und bei Bedarf korrigierend einzugreifen. Diese regelmäßige Überwachung sichert die nachhaltige Verbesserung des Sicherheitsniveaus.

Dieses Verfahren sollte folgende Elemente umfassen:

- ein Verfahren für die systematische Nachverfolgung der Maßnahmenumsetzung
- Dokumentation des aktuellen Umsetzungsstands und etwaiger Abweichungen vom Plan
- Frühzeitige Identifikation von Hindernissen oder Verzögerungen
- Eskalationspfade für Maßnahmen, die nicht planmäßig umgesetzt werden können
- Regelmäßige Statusberichte an Verantwortliche und das Management (z.B. im Managementbericht)
- ein Verfahren zur kontinuierlichen Fortschreibung des Umsetzungsplans, um auf veränderte Bedingungen oder neue Erkenntnisse reagieren zu können.

Die Fortschrittsverfolgung sollte in regelmäßigen Abständen erfolgen und den aktuellen Status jeder Maßnahme transparent dokumentieren. Bei Verzögerungen oder Problemen sollten frühzeitig geeignete Gegenmaßnahmen ergriffen werden.

Ein Verfahren zur kontinuierlichen Fortschreibung des Umsetzungsplans muss ebenfalls verankert werden. Dieses sollte sicherstellen, dass der Plan regelmäßig überprüft und bei Bedarf angepasst wird, um auf veränderte Bedingungen, neue Erkenntnisse oder unerwartete Herausforderungen zu reagieren. Die Fortschreibung kann umfassen:

- Anpassung von Zeitplänen und Ressourcenzuweisungen
- Neubewertung von Prioritäten
- Ergänzung neuer Maßnahmen oder Streichung nicht mehr relevanter Maßnahmen
- Integration von Erkenntnissen aus der Wirksamkeitsprüfung

Die Fortschreibung des Umsetzungsplans gewährleistet, dass dieser aktuell bleibt und neue Erkenntnisse, veränderte Rahmenbedingungen oder angepasste Prioritäten berücksichtigt werden (siehe Prozessschritt 5 - kontinuierliche Verbesserung). Der Plan sollte als lebendes Dokument betrachtet werden, das regelmäßig überprüft und angepasst wird.

4.7 Wahrung von Compliance in der Umsetzung

Die regelmäßige Überprüfung und Aktualisierung der Compliance-bezogenen Prozesse und Anweisungen stellt sicher, dass sie aktuell und wirksam bleiben, auch wenn sich die regulatorischen Anforderungen ändern. Diese kontinuierliche Anpassung ist ein wesentlicher Bestandteil eines lebendigen und effektiven Compliance-Managements innerhalb des ISMS. (siehe Prozessschritt 1-Erhebung und Planung).

Es ist ein Verfahren zu definieren (z.B. Prüflisten oder Auditierung), wie Compliance im Umsetzungsprozess überprüft wird.

5 Prozessschritt 4 – Überwachung

Der Prozessschritt der Überwachung dient der regelmäßigen Überwachung und Bewertung des ISMS und der umgesetzten Maßnahmen. Die zugrundeliegenden Anforderungen in der Praktik Monitoring und Evaluation sind entscheidend, um die Wirksamkeit des ISMS zu gewährleisten und eine fundierte Grundlage für Verbesserungsentscheidungen zu schaffen.

Die zentralen Elemente sind:

- die Etablierung von Verfahren zur systematischen Messung und Bewertung der ISMS-Leistung
- die regelmäßige und anlassbezogene Überwachung der Einhaltung von Compliance-Anforderungen
- die Planung und Durchführung eines strukturierten Auditprogramms mit risikoorientierten internen Audits
- die Anwendung einheitlicher Bewertungsschemata und die Erstellung aussagekräftiger Auditberichte
- die regelmäßige Durchführung von Managementbewertungen zur Überprüfung der Eignung, Angemessenheit und Wirksamkeit des ISMS. Die Ergebnisse der Managementbewertung sollten in einem Managementbericht dokumentiert werden.
- die Implementierung geeigneter Monitoring-Methoden und -tools zur frühzeitigen Erkennung von Sicherheitsvorfällen und Schwachstellen
- die regelmäßige Verifikation des Anforderungspakets auf seine Aktualität und Angemessenheit

Die folgende Abbildung zeigt die Fragestellungen auf, die in diesem Prozessschritt beantwortet werden.

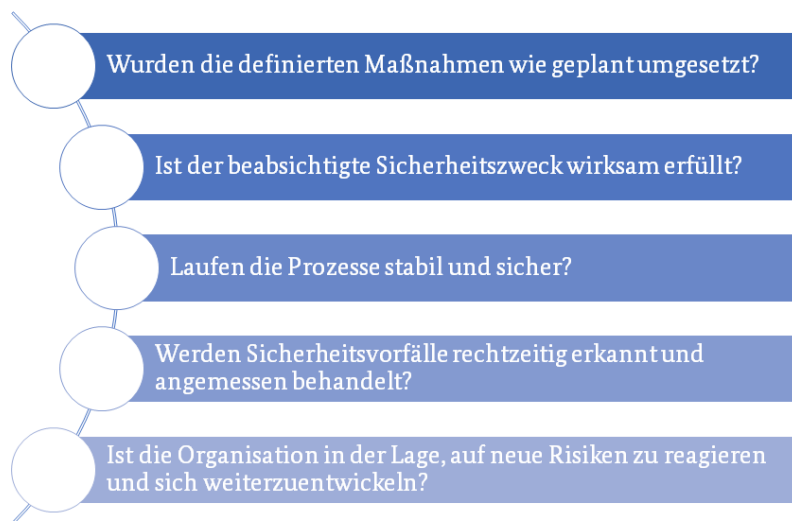


Abbildung 7 Prozessschritt 4: Überwachung

Das Ergebnis dieses Prozessschrittes ist ein umfassendes Bild des aktuellen Sicherheitsstatus, das sowohl technische wie organisatorische Aspekte berücksichtigt. Die gewonnenen Erkenntnisse fließen direkt in die Praktik Verbesserung ein und bilden die Grundlage für fundierte Managemententscheidungen.

5.1 Leistungsbewertung des ISMS

Die systematische Leistungsbewertung des ISMS ist von grundlegender Bedeutung, um den Erfolg der umgesetzten Anforderungen zu messen, Schwachpunkte zu identifizieren und kontinuierliche

Verbesserungen zu ermöglichen. Sie liefert die notwendigen Informationen für fundierte Managemententscheidungen und sichert die langfristige Wirksamkeit des ISMS.

Für eine effektive Leistungsbewertung müssen Verfahren und Regelungen zur Messung und Bewertung der ISMS-Leistung verankert werden.

Diese Verfahren sollten verschiedene Perspektiven und Informationsquellen berücksichtigen:

- Die Auswertung der Gefährdungslage in Bezug auf aktuelle Veränderungen ermöglicht eine proaktive Anpassung an neue Bedrohungen und stellt sicher, dass die Institution auf Veränderungen reagieren kann.
- Die Auswertung des Umsetzungsplans in Bezug auf den Fortschritt, die Einhaltung oder Überschreitung von Umsetzungsdaten und inhaltliche Korrektheit. Diese gibt Aufschluss über den aktuellen Status der Umsetzung.
- Die Überprüfung der Umsetzung von Maßnahmen zur Behandlung von Auditergebnissen und zur kontinuierlichen Verbesserung stellt sicher, dass identifizierte Schwachstellen behoben und Optimierungspotenziale genutzt werden.
- Die Auswertung von Maßnahmen aus der Nachbereitung von Sicherheitsvorfällen ermöglicht es, aus Vorfällen zu lernen und wiederkehrende Probleme durch geeignete präventive Maßnahmen zu vermeiden.

Die Leistungsbewertung des ISMS sollte alle Aspekte des ISMS umfassen und sowohl in regelmäßigen Abständen als auch anlassbezogen, durchgeführt werden. Die Ergebnisse sollten strukturiert dokumentiert, um die kontinuierliche Verbesserung des ISMS zu unterstützen.

5.2 Überwachung der Compliance

Die systematische Überwachung der Einhaltung von gesetzlichen, regulatorischen und vertraglichen Verpflichtungen (Compliance) ist ein zentraler Aspekt des Monitorings und der Evaluation. Sie dient der Vermeidung rechtlicher Konsequenzen, finanzieller Verluste und Reputationsschäden durch Compliance-Verstöße.

Im Rahmen der Compliance-Überwachung sollte die Einhaltung von Verpflichtungen regelmäßig sowie anlassbezogen überprüft werden. Dies umfasst:

- Regelmäßige Kontrollen zur Überprüfung der Einhaltung dokumentierter gesetzlicher und vertraglicher Anforderungen
- Anlassbezogene Überprüfungen bei Änderungen des regulatorischen Umfelds, bei Hinweisen auf mögliche Verstöße oder nach durchgeführten Änderungen in relevanten Systemen oder Prozessen
- Identifikation von Compliance-Lücken und deren systematische Dokumentation
- Entwicklung und Umsetzung von Maßnahmen zur Schließung identifizierter Compliance-Lücken

Die Überwachungsaktivitäten sollten risikoorientiert erfolgen, wobei besonderes Augenmerk auf Bereiche mit hoher rechtlicher Relevanz oder potenziell schwerwiegenden Konsequenzen bei Verstößen gelegt werden sollte. Die Ergebnisse der Compliance-Überwachung sollten dokumentiert und in den kontinuierlichen Verbesserungsprozess eingespeist werden.

5.3 Auditprogramm und -durchführung

Ein systematisches Auditprogramm¹ ist ein wesentliches Instrument zur unabhängigen Überprüfung und Bewertung der Wirksamkeit des ISMS.

¹ Der Begriff Auditprogramm ist synonym z.B. zu Revisionsprogramm.

Für den Aufbau und die Durchführung eines wirksamen Auditprogramms sind folgende Elemente erforderlich:

- Ein Verfahren zum Aufbau und zur Pflege eines oder mehrerer Auditprogramme muss verankert werden, dass die systematische Planung, Durchführung und Nachverfolgung von Audits ermöglicht.
- Für jedes durchzuführende Audit sollten Auditpläne dokumentiert werden, die folgende Elemente enthalten: Auditziele, Auditumfang, Auditkriterien, zu auditierende Standorte, eingesetzte Auditmethoden, Rollen und Zuständigkeiten.
- Die Planung der internen Audits im Auditprogramm muss risikoorientiert erfolgen und dokumentiert werden. Dabei sollte sichergestellt werden, dass die Effektivität und Effizienz aller angewandten Praktiken mindestens einmal sinnvoll geprüft werden.
- Ein Verfahren zur Auswahl von fachlich geeigneten und unabhängigen Auditoren muss etabliert werden, um die Objektivität und Qualität der Audits zu gewährleisten. Die Auditoren sollten über die erforderlichen Kenntnisse und Erfahrungen verfügen und von den zu auditierenden Bereichen unabhängig sein.
- Audits müssen in angemessenem Umfang durchgeführt werden, um aussagekräftige Ergebnisse zu liefern, ohne übermäßige Ressourcen zu binden.

Die Durchführung von Audits sollte nach einem strukturierten Prozess erfolgen, der die Vorbereitung, Durchführung, Berichterstattung und Nachverfolgung umfasst. Der Prozess sollte flexible Methoden wie Interviews, Dokumentenprüfungen, Beobachtungen oder Stichproben ermöglichen, die je nach Auditgegenstand und -ziel angemessen kombiniert werden können.

Ein gut konzipiertes und durchgeführtes Auditprogramm liefert wertvolle Erkenntnisse über die Wirksamkeit des ISMS und bildet eine wichtige Grundlage für die kontinuierliche Verbesserung der Informationssicherheit.

5.4 Bewertungsschema und Auditberichte

Die Erstellung aussagekräftiger Auditberichte auf Basis einheitlicher Bewertungsschemata ist entscheidend für die Wirksamkeit des Auditprozesses und die Vergleichbarkeit der Ergebnisse. Ein strukturiertes Vorgehen in diesem Bereich fördert die Objektivität der Bewertung und erleichtert die Kommunikation und Nachverfolgung der Feststellungen.

Für eine effektive Bewertung und Berichterstattung sind folgende Elemente zu etablieren:

- Auditergebnisse müssen in strukturierten Berichten dokumentiert werden, die eine klare und nachvollziehbare Darstellung der Feststellungen, ihrer Bewertung und der empfohlenen Maßnahmen enthalten. Die Berichte sollten sowohl für das Management als auch für die fachlich Verantwortlichen verständlich sein.
- Ein einheitliches Bewertungsschema für Feststellungen in Audits sollte verankert werden, um die konsistente Bewertung und Vergleichbarkeit von Auditergebnissen sicherzustellen.
- Die Auditberichte sollten neben den identifizierten Schwachstellen auch positive Feststellungen enthalten, um ein ausgewogenes Bild zu vermitteln und Best Practices zu fördern.
- Eine angemessene Kommunikation der Auditergebnisse an alle relevanten Stakeholder muss sichergestellt werden, um das Bewusstsein für identifizierte Risiken zu schärfen und die Umsetzung von Verbesserungsmaßnahmen zu fördern.

Das Bewertungsschema und die Struktur der Auditberichte sollten an die Größe und Komplexität der Institution angepasst sein. Während in kleineren Institutionen einfachere Schemata und Berichtsformate ausreichend sein können, benötigen größere und komplexere Institutionen oft differenziertere Ansätze, um

die verschiedenen Aspekte und Ebenen der Informationssicherheit angemessen zu erfassen und zu bewerten.

Eine transparente und konsistente Bewertung und Berichterstattung schafft eine solide Grundlage für die Nachverfolgung von Feststellungen und die kontinuierliche Verbesserung des ISMS.

5.5 Managementbewertung

Die Ergebnisse der Managementbewertung sollten in einem Managementbericht dokumentiert und in konkrete Entscheidungen und Maßnahmen zur Weiterentwicklung des ISMS überführt werden. Diese bilden die Grundlage für die strategische Ausrichtung der Informationssicherheit und fließen in die Planung der Ressourcen und Prioritäten für den kommenden Berichtszeitraum ein.

Die regelmäßige Durchführung von Managementbewertungen fördert die kontinuierliche Aufmerksamkeit der Institutionsleitung für das Thema Informationssicherheit und stellt sicher, dass das ISMS nicht nur operativ funktioniert, sondern auch strategisch ausgerichtet bleibt und die Ziele der Institution unterstützt. Sie schafft zudem einen formalen Rahmen für die Dokumentation wichtiger Entscheidungen zur Informationssicherheit, was besonders bei späteren Audits oder im Falle von Sicherheitsvorfällen von Bedeutung sein kann.

5.6 Monitoringmethoden und -tools

Effektive Monitoring-Methoden und -tools sind essentiell, um die regelmäßige Überwachung der Informationssicherheit zu gewährleisten und frühzeitig auf Sicherheitsvorfälle, Schwachstellen und neue Risiken reagieren zu können. Sie bilden die technische und methodische Grundlage für eine proaktive Informationssicherheit.

Im Rahmen des Monitorings müssen folgende Verfahren verankert werden:

- Ein Verfahren zur Erkennung von Sicherheitsvorfällen, das die frühzeitige Identifikation und Meldung von Vorfällen ermöglicht. Dies kann von manuellen Prozessen bis hin zu automatisierten Erkennungssystemen reichen, je nach Größe und Komplexität der Institution.
- Ein Verfahren für den Umgang mit Schwachstellen und ihre Berücksichtigung in der Risikobetrachtung. Dieses Verfahren sollte die systematische Identifikation, Bewertung, Behandlung und Nachverfolgung von Schwachstellen umfassen.
- Ein Verfahren für die Erkennung und die Reaktion auf neu auftretende Bedrohungen und ihre Berücksichtigung in der Risikobetrachtung ist zu etablieren.
- In größeren Institutionen oder bei hohem Schutzbedarf können spezialisierte Tools die Überwachung unterstützen:
 - Security Information and Event Management (SIEM) Systeme für die zentrale Sammlung, Korrelation und Analyse von Sicherheitsereignissen aus verschiedenen Quellen
 - Intrusion Detection/Prevention Systeme (IDS/IPS) zur Erkennung und Abwehr verdächtiger Netzwerkaktivitäten
 - Vulnerability Management Systeme zur systematischen Identifikation und Behandlung von Schwachstellen
 - Configuration Monitoring Tools zur Überwachung von Konfigurationsänderungen in Systemen und Anwendungen

Die Implementierung dieser Monitoring-Methoden und -tools sollte an die individuellen Bedürfnisse und Möglichkeiten der Institution angepasst sein. Während kleinere Institutionen mit einfacheren Lösungen arbeiten können, benötigen größere und komplexere Umgebungen oft umfassendere und stärker automatisierte Ansätze.

Die gewonnenen Monitoring-Daten sollten systematisch ausgewertet und für verschiedene Zwecke genutzt werden, darunter die Erstellung von Kennzahlen und Berichten, die Früherkennung von Sicherheitsrisiken, die Unterstützung der Incident Response und die kontinuierliche Verbesserung des ISMS.

5.7 Validierung der Anforderungen

Die regelmäßige Überprüfung der Aktualität der Anforderungen ist für die Aufrechterhaltung des Sicherheitsniveaus wichtig. Im Aspekt des Monitorings und der Evaluation, muss sichergestellt werden, dass die gewählten Anforderungen weiterhin für den Informationsverbund angemessen und aktuell sind. Dieser Prozess hilft, die Modellierung des ISMS an veränderte Bedingungen anzupassen und die Wirksamkeit des Sicherheitskonzeptes zu gewährleisten.

Die Validierung sollte folgende Aspekte umfassen:

- Das Anforderungspaket sollte regelmäßig (i.A. jährlich, je nach Organisationsgröße, Parameter und Prüftiefe) im Hinblick auf die Modellierung überprüft werden, um ihre Aktualität und Angemessenheit zu bewerten.
- Bei der Überprüfung sollten veränderte Geschäftsprozesse, neue IT-Komponenten, organisatorische Änderungen und externe Faktoren wie neue regulatorische Anforderungen oder veränderte Bedrohungslandschaften sowie neue Anforderungen im GS++ und die Zielobjekt-Hierarchie berücksichtigt werden.
- Die Überprüfung sollte in Abstimmung mit den zuständigen Bereichen erfolgen, um sicherzustellen, dass alle relevanten Perspektiven einbezogen werden.
- Bei Bedarf sollten Anpassungen der Auswahl der Anforderungen vorgenommen werden, um den aktuellen Anforderungen gerecht zu werden (Prozessschritt 4).

Die Verifikation dient nicht nur der Aktualisierung des ISMS-Modells, sondern auch als Qualitätssicherungsmaßnahme. Sie stellt sicher, dass die grundlegende Struktur des ISMS mit den tatsächlichen Gegebenheiten der Institution übereinstimmt und dass keine relevanten Anforderungen übersehen werden. Die Ergebnisse der Verifikation sollten dokumentiert und in die kontinuierliche Verbesserung des ISMS einbezogen werden. Wenn signifikante Anpassungen erforderlich sind, führen diese zu einer Neumodellierung oder Erweiterung des Anforderungspakets, was wiederum den gesamten Zyklus der Strukturmodellierung und Umsetzung gemäß PDCA-Zyklus beeinflusst.

Das Monitoring und die Evaluation sind entscheidend für die Wirksamkeit und kontinuierliche Verbesserung des ISMS. Durch die systematische Leistungsbewertung, die Überwachung der Compliance, ein strukturiertes Auditprogramm, aussagekräftige Bewertungsschemata und Berichte, regelmäßige Managementbewertungen, effektive Monitoring-Methoden und eine Verifikation wird sichergestellt, dass das ISMS seinen Zweck erfüllt und sich dynamisch an veränderte Anforderungen anpassen kann. Die in diesem Prozessschritt gewonnenen Erkenntnisse bilden die Grundlage für die kontinuierliche Verbesserung des ISMS und unterstützen die Institution dabei, ein angemessenes Sicherheitsniveau zu erreichen und aufrechtzuerhalten. Sie liefern zudem wichtige Informationen für strategische Entscheidungen zur Weiterentwicklung der Informationssicherheit und zur Ausrichtung an den Institutionszielen der Institution.

6 Prozessschritt 5 – kontinuierliche Verbesserung

Die kontinuierliche Verbesserung schließt den PDCA-Zyklus der Methodik-GS++ ab und stellt sicher, dass die Informationssicherheit stetig weiterentwickelt und verbessert wird. In diesem Prozessschritt werden Erkenntnisse aus der Überwachung in konkrete Verbesserungsmaßnahmen umgesetzt.

Die kontinuierliche Verbesserung umfasst:

- die systematische Analyse von Nicht-Konformitäten hinsichtlich ihrer Ursachen und möglichen Wiederauftretens und deren Berücksichtigung in der Risikobetrachtung.
- die Identifikation und Bewertung von Verbesserungspotenzialen und deren Berücksichtigung in der Risikobetrachtung
- die Einleitung angemessener Korrekturmaßnahmen zur Beseitigung von Fehlerursachen und Maßnahmen zur Nutzung von Verbesserungspotenzialen
- die risikoorientierte Priorisierung von Verbesserungsmaßnahmen und die eindeutige Zuweisung von Zuständigkeiten
- die systematische Nachverfolgung des Umsetzungsfortschritts und die Überprüfung der Wirksamkeit der Verbesserungen
- die Bewertung der erreichten Verbesserung und ihre Auswirkung auf das Sicherheitsniveau
- die Etablierung und Anwendung eines strukturierten Verfahrens zur Behandlung von Compliance-Verstößen

Als Ergebnis dieses Prozessschrittes werden Schwachstellen und geänderte Bedrohungslagen identifiziert. Diese werden im Rahmen der Risikobetrachtung berücksichtigt und lösen einen Zyklus der Risikobetrachtung aus. So werden Risiken behandelt, Verbesserungspotenziale genutzt und das ISMS kontinuierlich an veränderte Rahmenbedingungen angepasst.

6.1 Umgang mit Nicht-Konformitäten

Der systematische Umgang mit Nicht-Konformitäten ist ein zentraler Bestandteil des kontinuierlichen Verbesserungsprozesses. Oberstes Ziel ist es, dass Nicht-Konformitäten durch Korrekturmaßnahmen abgestellt werden (siehe auch Kapitel 7.3).

Nicht-Konformitäten – also Abweichungen von definierten Anforderungen, Standards oder Erwartungen – stellen wichtige Indikatoren für Verbesserungspotenzial dar und müssen strukturiert behandelt werden, um die Wirksamkeit des ISMS zu steigern.

Im Rahmen des kontinuierlichen Verbesserungsprozesses muss eine Methode zur Überprüfung von Nicht-Konformitäten hinsichtlich ihrer Ursachen und möglichen Wiederauftretens verankert werden. Diese Methode sollte folgende Aspekte umfassen:

- eine systematische Erfassung und Dokumentation aller identifizierten Nicht-Konformitäten, unabhängig davon, ob sie durch interne Audits, externe Prüfungen, Vorfälle oder im Rahmen des regulären Betriebs entdeckt wurden,
- eine gründliche Ursachenanalyse, die nicht nur die unmittelbaren, sondern auch die grundlegenden Ursachen der Nicht-Konformität identifiziert (Root-Cause-Analysis),
- eine Bewertung der Wahrscheinlichkeit des Wiederauftretens und der potenziellen Auswirkungen bei erneutem Auftreten,
- eine Überprüfung, ob ähnliche Nicht-Konformitäten in anderen Bereichen der Institution bestehen oder auftreten könnten und

- eine Analyse, inwieweit die Nicht-Konformität auf systemische Schwächen im ISMS hinweist und ob grundlegende Anpassungen des ISMS erforderlich sind.

Die Nicht-Konformitäten und die Erkenntnisse aus deren Ursachenanalyse sollten in der Risikobetrachtung hinsichtlich der Notwendigkeit zur Anpassung des ISMS überprüft werden. Nicht jede Nicht-Konformität erfordert strukturelle Änderungen am ISMS; einige können durch isolierte Korrekturmaßnahmen behoben werden. Bei wiederholten oder systematischen Nicht-Konformitäten sollten jedoch die zugrundeliegenden Prozesse, Richtlinien oder Verantwortlichkeiten überprüft und bei Bedarf angepasst werden.

Ein wirksamer Umgang mit Nicht-Konformitäten fördert die Lernkultur innerhalb der Institution und hilft, wiederkehrende Probleme zu vermeiden. Die transparente Dokumentation und Kommunikation der Ergebnisse unterstützt zudem die Sensibilisierung für Informationssicherheitsaspekte und die kontinuierliche Verbesserung des gesamten ISMS.

6.2 Identifikation von Verbesserungspotenzialen

Die Identifikation von Verbesserungspotenzialen ist ein wesentlicher Treiber für die kontinuierliche Weiterentwicklung und Verbesserungen des ISMS. Im Gegensatz zum reaktiven Umgang mit Nicht-Konformitäten zielt dieser Ansatz darauf ab, auch ohne vorangegangene Probleme oder Abweichungen Optimierungsmöglichkeiten zu erkennen und zu nutzen.

Eine Methode zur Überprüfung und Bewertung von Verbesserungspotenzialen und deren Berücksichtigung in der Risikobetrachtung sollte verankert werden. Diese Methode beinhaltet typischerweise:

- die Bewertung des Umfelds der Institution (z. B. Bewertung der Gefährdungslage), um frühzeitig auf veränderte externe Faktoren reagieren zu können und neue Ansätze zur Risikominimierung zu identifizieren,
- die systematische Auswertung des Umsetzungsplans, um Erkenntnisse über Effizienz und Effektivität der bisherigen Maßnahmenplanung und -umsetzung zu gewinnen,
- die Analyse von Auditergebnissen nicht nur hinsichtlich identifizierter Schwachstellen, sondern auch in Bezug auf mögliche Prozessoptimierungen und Best Practices,
- die Auswertung von Sicherheitsvorfällen, um über die unmittelbare Behebung hinaus langfristige Verbesserungen zu initiieren und
- die Berücksichtigung von Ad-hoc-Eingaben (z.B. Vorschläge von Mitarbeitenden, neue technologische Entwicklungen), die akute Verbesserungspotenziale aufzeigen können.

Zur Bewertung von Verbesserungspotenzialen ist eine Berücksichtigung dieser in der Risikobetrachtung wichtig.

Nicht jede Verbesserungsmöglichkeit bietet denselben Mehrwert für die Institution.

Die Bewertung sollte daher folgende Aspekte berücksichtigen:

- das Potenzial zur Risikoreduktion
- den erwarteten Ressourcenaufwand
- die strategische Bedeutung für die Informationssicherheitsziele
- mögliche Synergien mit anderen Verbesserungsmaßnahmen oder Projekten
- die Nachhaltigkeit der Verbesserung

Die systematische Identifikation und Bewertung von Verbesserungspotenzialen fördert eine zukunftsorientierte Sicherheitskultur und unterstützt die Institution dabei, ihr ISMS kontinuierlich an neue Anforderungen und Möglichkeiten anzupassen. Sie ist ein wesentlicher Bestandteil eines lebenden ISMS, das sich proaktiv weiterentwickelt, anstatt nur auf Probleme zu reagieren.

6.3 Korrektur- und Verbesserungsvorschläge

Auf Basis der identifizierten Nicht-Konformitäten und Verbesserungspotenziale müssen angemessene Korrektur- und Verbesserungsvorschläge entwickelt und umgesetzt werden. Diese Vorschläge bilden den aktiven Teil des kontinuierlichen Verbesserungsprozesses und überführen die gewonnenen Erkenntnisse in konkrete Handlungen in den anstehenden Durchführungszyklen (PDCA-Zyklus).

Bei der Entwicklung von Korrekturvorschlägen zur Beseitigung von Fehlerursachen sollten folgende Aspekte berücksichtigt werden:

- Die vorgeschlagenen Korrekturen müssen die identifizierten Grundursachen adressieren und nicht nur die Symptome beheben.
- Die Korrekturen sollten angemessen und verhältnismäßig sein, also in einem sinnvollen Verhältnis zum Risiko oder zur Bedeutung der Nicht-Konformität stehen. Zur Bewertung von Korrektur und Verbesserungsvorschlägen ist eine Berücksichtigung dieser in der Risikobetrachtung wichtig.
- Die Korrekturen sollten nachhaltig wirken und wiederkehrende Probleme verhindern.
- Je nach Ursache können unterschiedliche Arten von Korrekturen erforderlich sein:
 - Organisatorische Anpassungen wie die Überarbeitung von Prozessen, Richtlinien oder Zuständigkeiten
 - Personelle Maßnahmen wie Schulungen, Sensibilisierung oder in schwerwiegenden Fällen disziplinarische Schritte
 - Infrastrukturelle Änderungen wie bauliche Anpassungen oder Verbesserungen der physischen Sicherheit
 - Technische Anpassungen an Hardware, Software oder Netzwerkinfrastruktur
 - Strategische Maßnahmen, die eine Entscheidung oder Unterstützung der Institutionsleitung erfordern

Für Verbesserungen zur Nutzung identifizierter Potenziale sollte ein ähnlich strukturierter Ansatz verfolgt werden. Diese Korrekturen zielen nicht primär auf die Behebung von Problemen, sondern auf die proaktive Weiterentwicklung des ISMS. Sie können beispielsweise folgende Bereiche adressieren:

- Optimierung von Prozessen und Abläufen im ISMS
- Einführung neuer oder verbesserter Technologien und Methoden
- Stärkung der Sicherheitskultur und des Sicherheitsbewusstseins
- Erweiterung des Anwendungsbereiches des ISMS
- Verbesserung der Integration des ISMS in andere Managementsysteme und Geschäftsprozesse

Sowohl Korrekturen als auch Verbesserungen sollten sorgfältig geplant, dokumentiert und nachverfolgt werden (siehe Prozessschritt 1). Die angemessene Ressourcenausstattung und die klare Zuweisung von Verantwortlichkeiten sind dabei entscheidende Erfolgsfaktoren.

6.4 Korrektur- und Verbesserungsplanung

Die systematische Priorisierung und Umsetzung der identifizierten Korrekturen und Verbesserungen ist entscheidend für einen effektiven kontinuierlichen Verbesserungsprozess. Angesichts begrenzter Ressourcen müssen Institutionen sicherstellen, dass die wichtigsten Änderungen zuerst umgesetzt werden und alle Aktivitäten koordiniert ablaufen.

Dabei sollte die Korrektur und Verbesserungsplanung direkt in den Umsetzungsplan mit einfließen. (siehe Prozessschritte 3 Realisierung).

Die festgelegten Korrekturen, Verbesserungen, Zuständigkeiten und Fristen sollten in geeigneter Form dokumentiert werden, beispielsweise in einem Projektmanagement- oder Ticketsystem. Bei komplexeren Änderungen kann es sinnvoll sein, sowohl eine fachliche als auch eine operative Verantwortung zu definieren und bei Bedarf Teilaufgaben mit eigenen Verantwortlichkeiten und Fristen zu bilden.

Eine transparente Kommunikation des Korrektur- und Verbesserungsplans an alle Beteiligten fördert das gemeinsame Verständnis und die Akzeptanz. Regelmäßige Statusberichte und Updates (z.B. im Managementbericht), helfen den Fortschritt zu überwachen und bei Bedarf frühzeitig gegenzusteuern.

Die Priorisierung und Umsetzung von Korrekturen und Verbesserungen stellen sicher, dass die kontinuierliche Verbesserung nicht nur theoretisch bleibt, sondern zu konkreten und messbaren Fortschritten führt. Sie unterstützt die Institution dabei, ihre begrenzten Ressourcen optimal einzusetzen und die größtmögliche Wirkung im Sinne der Informationssicherheit zu erzielen.

6.5 Wirksamkeitsprüfung

Eine systematische Wirksamkeitsprüfung ist unverzichtbar, um den Erfolg der kontinuierlichen Verbesserung zu gewährleisten und bei Bedarf rechtzeitig nachsteuern zu können. Dieser Prozess schließt die Lücke zwischen der Planung und Umsetzung von Maßnahmen einerseits und der Bewertung ihrer tatsächlichen Wirkung andererseits.

Neben der reinen Fortschrittsverfolgung ist die Überprüfung der Wirksamkeit umgesetzter Maßnahmen von entscheidender Bedeutung. Während die Fortschrittsverfolgung (siehe Prozessschritt 3 Thema: Fortschrittsverfolgung der Realisierung) prüft, ob eine Maßnahme wie geplant umgesetzt wurde, bewertet die Wirksamkeitsprüfung, ob die Maßnahme auch den beabsichtigten Effekt erzielt hat. Hierfür sollten folgende Aspekte berücksichtigt werden:

- Definition klarer, messbarer Kriterien für die Wirksamkeit jeder Maßnahme
- Durchführung gezielter Tests, Audits oder Überprüfungen nach Abschluss der Umsetzung
- Bewertung, ob die identifizierten Nicht-Konformitäten tatsächlich beseitigt oder die angestrebten Verbesserungen erreicht wurden
- Dokumentation der Ergebnisse der Wirksamkeitsprüfung

Die Wirksamkeitsprüfung stellt sicher, dass der kontinuierliche Verbesserungsprozess zu messbaren und nachhaltigen Fortschritten führt. Sie schaffen Transparenz über den aktuellen Status und unterstützen die Institution dabei, ihre Ressourcen optimal einzusetzen und den Erfolg ihrer Verbesserungsbemühungen zu demonstrieren.

6.6 Bewertung der erreichten Verbesserung

Die systematische Bewertung der erreichten Verbesserungen ist ein wesentlicher Schritt, um den Erfolg des kontinuierlichen Verbesserungsprozesses zu messen und zukünftige Entwicklungen zu steuern. Sie schafft Transparenz über die erzielten Fortschritte und ermöglicht eine fundierte Entscheidungsfindung für die weitere Entwicklung des ISMS.

Für eine strukturierte Bewertung sollte ein Verfahren zur Bewertung der umgesetzten Verbesserungspotenziale hinsichtlich der Risiken verankert werden.

Dieses Verfahren sollte folgende Aspekte umfassen:

- Eine risikoorientierte Beurteilung der Wirkung umgesetzter Verbesserungsmaßnahmen auf das Gesamtrisiko der Institution. Zur Bewertung von Verbesserungspotenzialen ist eine Berücksichtigung dieser in der Risikobetrachtung wichtig.
- Eine Analyse des Verhältnisses zwischen investierten Ressourcen und erzielten Verbesserungen (Return on Security Investment).

- Eine Bewertung des Beitrags der Verbesserungen zur Erreichung der strategischen Informationssicherheitsziele.
- Eine Überprüfung der Nachhaltigkeit der erzielten Verbesserungen.

Ein zentrales Element der Bewertung ist die transparente Darstellung des Sicherheitsniveaus der Institution. Diese sollte so gestaltet sein, dass sie für verschiedene Zielgruppen, insbesondere für die Institutionsleitung, verständlich und aussagekräftig ist.

Dazu können beispielsweise folgende Instrumente eingesetzt werden:

- Grafische Darstellungen des Sicherheitsniveaus in verschiedenen Bereichen
- Kennzahlen zur Messung des Sicherheitszustands
- Vergleiche mit Branchen-Benchmarks oder Standards
- Trendanalysen zur Visualisierung der Entwicklung über die Zeit

Ein besonderer Fokus sollte auf der Trendanalyse im Vergleich zu vorherigen Bewertungen liegen. Diese ermöglicht es, die Entwicklung des Sicherheitsniveaus über längere Zeiträume zu verfolgen und frühzeitig Verbesserungen oder Verschlechterungen zu erkennen. Folgende Aspekte sind dabei relevant:

- Konsistente Bewertungsmethodik über verschiedene Zeitpunkte hinweg, um Vergleichbarkeit zu gewährleisten
- Berücksichtigung veränderter Rahmenbedingungen oder neuer Anforderungen bei der Interpretation von Trends
- Analyse von Korrelationen zwischen umgesetzten Maßnahmen und beobachteten Veränderungen des Sicherheitsniveaus
- Identifikation von Bereichen mit positiver oder negativer Entwicklung als Grundlage für zukünftige Prioritätensetzung

Im Ergebnis ist das Sicherheitsniveau der Institution transparent dargestellt und Trends in der Entwicklung (insbesondere auch durch die Vergleichbarkeit mit vorigen Bewertungen) werden deutlich. Diese Informationen bilden eine wichtige Grundlage für strategische Entscheidungen im Bereich der Informationssicherheit und ermöglichen eine kontinuierliche Anpassung und Verbesserung des ISMS.

6.7 Behandlung von Compliance-Verstößen

Die systematische Behandlung von Compliance-Verstößen trägt dazu bei, die Einhaltung regulatorischer, vertraglicher und interner Anforderungen sicherzustellen. Ein strukturierter Umgang mit Verstößen hilft, ähnliche Vorfälle in Zukunft zu vermeiden.

Ein Verfahren zur Behandlung von Verstößen sollte verankert werden, das folgende Elemente umfasst:

- Klare Definition, was als Verstoß gilt und wie verschiedene Arten von Verstößen kategorisiert werden
- Festlegung von Melde- und Eskalationswegen für erkannte oder vermutete Verstöße
- Systematischer Prozess zur Untersuchung und Dokumentation von Verstößen
- Entscheidungsfindung über angemessene Reaktionen und Konsequenzen
- Nachverfolgung der Umsetzung beschlossener Maßnahmen

Die Reaktionen auf Verstöße sollten verhältnismäßig und angemessen sein. Dabei sind stets die Rechte und Freiheiten der Betroffenen zu berücksichtigen, insbesondere die Verhältnismäßigkeit.

Neben der unmittelbaren Reaktion auf Verstöße sollten Prozesse zur Vermeidung künftiger Verstöße etabliert werden. Dazu gehören:

- Analyse der Ursachen des Verstoßes (organisatorisch, technisch, menschlich)
- Identifikation von Verbesserungspotenzialen in Prozessen, Schulungen oder Kontrollen
- Umsetzung präventiver Maßnahmen wie verbesserte Schulungskonzepte, technische Sicherheitsmechanismen oder Prozessänderungen
- Sensibilisierung relevanter Gruppen von Mitarbeitenden für typische Compliance-Risiken

Bei schwerwiegenden Verstößen oder komplexen rechtlichen Fragestellungen sollte rechtliche Expertise hinzugezogen werden. Dies kann durch interne Rechtsabteilungen oder externe Rechtsberater erfolgen und dient dazu, rechtlich korrekte und angemessene Entscheidungen zu treffen sowie mögliche rechtliche Konsequenzen für die Institution zu minimieren.

Eine strukturierte und angemessene Behandlung von Compliance-Verstößen fördert die Entwicklung einer positiven Sicherheits- und Compliance-Kultur in der Institution. Sie zeigt, dass Regelverstöße ernst genommen werden, stellt aber gleichzeitig sicher, dass der Fokus auf Lernen und Verbesserung liegt und nicht ausschließlich auf Sanktionen.

7 Grundlegende Begriffe

Dieses Glossar enthält alphabetisch sortierte Grundbegriffe und Definitionen im Kontext der Methodik-GS++. Es wird fortlaufend erweitert und bei Bedarf ergänzt.

7.1 Anforderungen

Anforderungen beschreiben, was getan werden muss, um ein bestimmtes Niveau bezüglich der Informationssicherheit zu erreichen. Diese behandeln organisatorische, personelle, infrastrukturelle und technische Themen. Wie die Anforderungen im konkreten Fall erfüllt werden können, ist in entsprechenden Maßnahmen beschrieben.

Das Modalverb ²einer Anforderung gibt an, welchen Pflichtcharakter sie hat, d.h. ob es sich um eine MUSS-, SOLLTE- oder KANN-Anforderung handelt.

Für die Anforderungen gelten folgende Definitionen:

- MUSS → verpflichtend, keine Abweichung erlaubt (entspricht „MUST“).
- SOLLTE → in der Regel verpflichtend, Abweichung in begründeten Ausnahmefällen möglich (entspricht „SHOULD“).
- KANN → optional, je nach Situation sinnvoll, aber nicht notwendig (entspricht „MAY“).

Die Modalverben werden ähnlich dem RFC 2119 aber im deutschen Kontext angewandt.

7.2 Assets

Assets sind alle Werte, Ressourcen oder Komponenten, die für eine Institution einen Wert besitzen und im Rahmen der Informationssicherheit geschützt werden müssen und zur Erreichung von Institutionszielen, benötigt werden.

7.3 Geltungsbereich des ISMS

Der Geltungsbereich (Scope) des ISMS beschreibt, wo und für wen das ISMS gilt und legt den formalen und organisatorischen Umfang der Anwendung des Informationssicherheitsmanagementsystems (ISMS) fest. Der Geltungsbereich grenzt klar ab, welche Bereiche durch das ISMS geschützt und gesteuert werden.

7.4 Informationssicherheitsmanagementsystem (ISMS)

Das Informationssicherheitsmanagementsystem ist eine erforderliche Planungs-, Lenkungs- und Kontrollaufgabe, um einen ganzheitlichen Prozess für die Informationssicherheit aufzubauen. Dabei handelt es sich um einen kontinuierlichen Prozess (PDCA-Zyklus), dessen Strategien und Konzepte ständig auf ihre Leistungsfähigkeit und Wirksamkeit zu überprüfen und bei Bedarf fortzuschreiben sind.

7.5 Informationsverbund

Als Informationsverbund ist die Gesamtheit von infrastrukturellen, organisatorischen, personellen und technischen Objekten zu verstehen, die der Aufgabenerfüllung in einem bestimmten Anwendungsbereich der Informationsverarbeitung dienen. Ein Informationsverbund kann dabei als Ausprägung den gesamten Geltungsbereich des ISMS oder einzelne Bereiche, die durch organisatorische Strukturen oder gemeinsame Geschäftsprozesse bzw. Anwendungen gegliedert sind, umfassen.

² Die Modalverben werden ähnlich dem RFC 2119 aber im deutschen Kontext angewandt.

7.6 Maßnahmen

Als Maßnahmen werden alle Aktionen bezeichnet, die dazu dienen, um Sicherheitsrisiken zu steuern und um diesen entgegenzuwirken. Sie beschreiben, wie Anforderungen erfüllt werden. Dies schließt sowohl organisatorische, als auch personelle, technische oder infrastrukturelle Maßnahmen ein.

7.7 Praktiken

Praktiken bündeln Anforderungen nach Tätigkeiten, deren Zuständigkeit bestimmten Rollen zuordenbar sind. Dies ermöglicht eine schnelle Zuordnung von Anforderungen zu Prozessen und zuständigen Rollen, die für die Umsetzung verantwortlich sind. Jede Anforderung ist in genau einer Praktik zugeordnet.

Praktiken lassen sich unterteilen in:

- ISMS-Praktiken
- Organisatorische Praktiken
- Technische Praktiken

Die ISMS-Praktiken sind übergreifend. Sie bauen einen Plan-Do-Check-Act-Zyklus (PDCA-Zyklus) des Managementsystems auf, der die fortlaufende Kontrolle und Verbesserung über alle Bereiche hinweg gewährleistet.

7.8 Risikobetrachtung

Die Risikobetrachtung ist ein Instrument, um zu ermitteln, welchen Risiken eine Institution ausgesetzt ist, um diese strukturiert und systematisch zu behandeln.

7.9 Schutzbedarf

Der Schutzbedarf beschreibt, wie stark z.B. Geschäftsprozesse, Informationen oder Systeme geschützt werden müssen. Er ergibt sich aus den Auswirkungen auf die Schutzziele der Informationssicherheit:

- Vertraulichkeit,
- Integrität und
- Verfügbarkeit.

Der Schutzbedarf im Grundschutz++ teilt sich in die Kategorien „normal“ und „hoch“.

7.10 Informationssicherheitseinstufung

Die Informationssicherheitseinstufung bezeichnet die prozessorientierte Zuordnung eines Schutzbedarfs zu Geschäftsprozessen und den dabei verarbeiteten Informationen.

7.11 Informationssicherheitsleitlinie

Die Informationssicherheitsleitlinie ist ein zentrales Dokument für die Informationssicherheit einer Institution. In ihr wird beschrieben, für welche Zwecke, mit welchen Mitteln und mit welchen Strukturen Informationssicherheit innerhalb der Institution hergestellt werden soll. Sie beinhaltet die von der Institution angestrebten Informationssicherheitsziele sowie die verfolgte Sicherheitsstrategie. Diese Leitlinie beschreibt damit auch über die Sicherheitsziele das angestrebte Sicherheitsniveau in einer Institution.

7.12 Sicherheitsniveau

Sicherheitsniveau beschreibt den Erfüllungsgrad von Sicherheitszielen durch umgesetzte organisatorische, technische, infrastrukturelle und personelle Anforderungen.

Es wird zwischen zwei Sicherheitsniveaus unterschieden:

- normal (Stand der Technik) und
- erhöht

Das Sicherheitsniveau ist im Anforderungskatalog für jede Anforderung festgelegt.

7.13 Zielobjektkategorien

Zielobjektkategorien sind Teile des Informationsverbunds, denen im Rahmen der Strukturmodellierung Anforderungen zugeordnet werden können.